

A VISUAL FIELD GUIDE · 2026 EDITION

Privacy Engineering

From First Principles to Real Products

First principles → engineering controls → product reviews → how Apple ships it. Four levels, one mental model.

PRIMER

REFERENCE

WORKSHOP

Built for the complete newbie and the working expert alike.

NEWBIE → EXPERT



One deck. Four levels. Three ways to read it.

Stop where you need. Each level revisits the same ideas at a deeper resolution.

0**MINDSET**

pp. 03–14

What privacy is — and is not — told through real-life scenarios.

1**FOUNDATIONS**

pp. 15–30

Data, identity, harms, lifecycle, law, consent, retention, deletion.

2**ENGINEERING**

pp. 31–64

PETs, threat models, reviews, cases — plus the tracking module.

3**IN PRACTICE**

pp. 65–113

Apple in its own words, the incentives underneath, then practice.

PICK YOUR PATH**New to privacy**

Levels 0 → 1, then the glossary on p. 114.
Say each slide's key idea out loud.

**Working engineer**

Skim Level 1. Live in Level 2 — PETs, threat models, enforcement.

**Teaching a session**

One real-life scenario (pp. 08–13), one case (pp. 47–49), then the drill (p. 85) and the one-page model (p. 113).

Start with the human problem.

Privacy is not a checkbox. It is the discipline of limiting unwanted exposure and unwanted use of information about people.

IN THIS LEVEL

THE ROLE

EXPOSURE

CONTEXTUAL INTEGRITY

PRIVACY ≠ SECURITY

REAL LIFE

CASE FILES

A privacy engineer turns promises into mechanisms

Lawyers write what must be true. Product decides what users should feel. You make the system actually behave that way.



HAT 01

The Reviewer

Reads designs before launch and finds the exposure nobody drew on the whiteboard.

OUTPUT

Findings, required changes, a risk rating



HAT 02

The Builder

Ships the controls: consent plumbing, deletion pipelines, DP libraries, access guards.

OUTPUT

Libraries, platforms, deploy gates



HAT 03

The Auditor

Checks what really runs: logs, joins, retention, and runtime enforcement.

OUTPUT

Invariants, dashboards, incident fixes

The job is not saying no. It is finding the design where the product works and the exposure shrinks.

Privacy is control over exposure

A system can be perfectly secure and still be privacy-invasive.



Ask three questions

1

What data is exposed?

Raw, derived, and inferred — inference counts as collection.

2

To whom — and why?

Every recipient needs a purpose you could say out loud to the user.

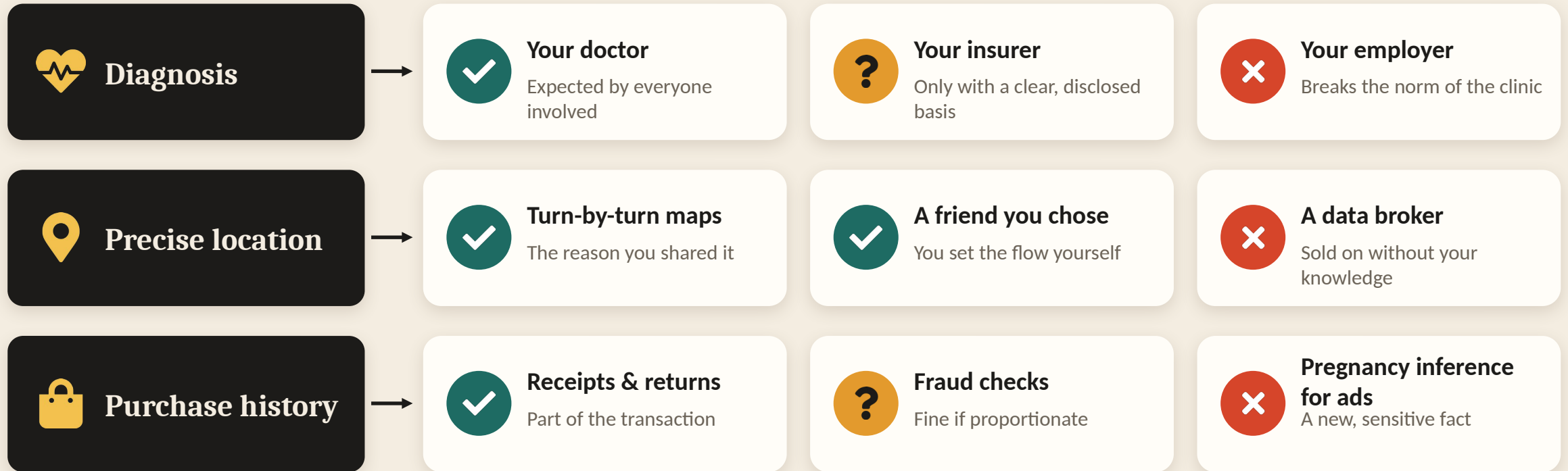
3

Can the user reasonably control it?

Understand it, stop it, correct it, delete it.

Same data. Different flow. Different verdict.

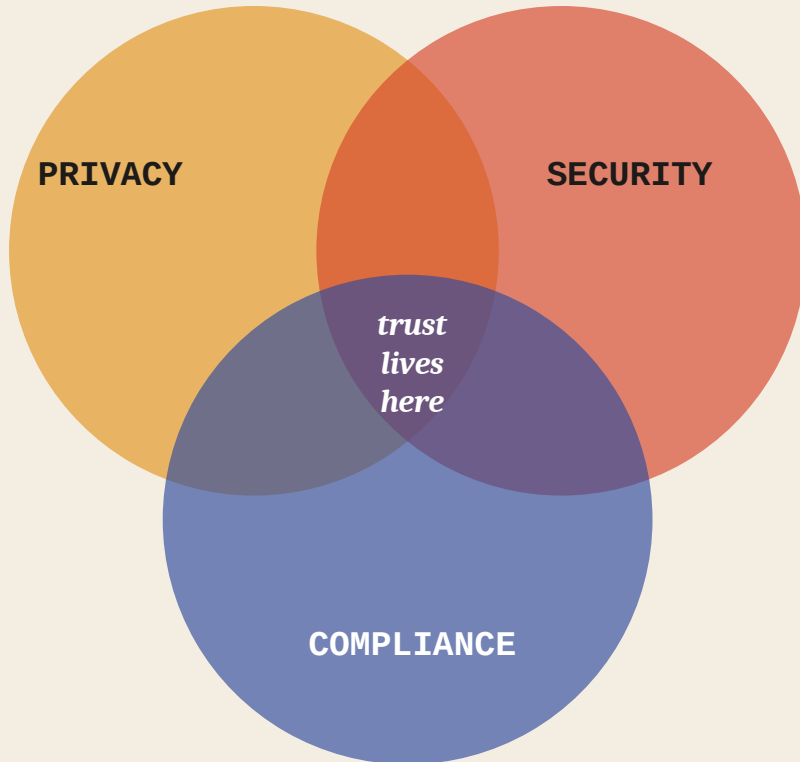
Helen Nissenbaum's idea: privacy breaks when information flows against the norms of the context it came from.



Reviewer's move: don't ask "is this data sensitive?" — ask "does this flow match what the user expected when they shared it?"

Privacy ≠ Security ≠ Compliance

They overlap. They are not substitutes. Strong candidates keep all three in view at once.



● **PRIVACY**

Should this data be collected, linked, retained, or used?

● **SECURITY**

Can unauthorized people or systems access or alter it?

● **COMPLIANCE**

Are legal, policy, and contractual obligations met?

WHERE THEY COME APART

Secure, not private

An encrypted, access-controlled database full of data the product never needed.

Compliant, not trusted

A consent box was ticked — yet users are shocked by how their data is used.

Private, not secure

Minimal data by design — exposed anyway through an unauthenticated debug endpoint.

Is privacy security, a law, or a feature?

All four words describe the same house. Each one answers a different question.



PRIVACY

The decision

IN THE HOUSE

*Which rooms guests may enter
— and why.*

THE QUESTION IT ANSWERS

**What should flow, to whom,
for what purpose?**

♪ *Photo analysis stays on the
iPhone.*



SECURITY

The locks

IN THE HOUSE

*Doors, alarm, and the safe that
keep the decision true.*

THE QUESTION IT ANSWERS

**Can an attacker break the
decision?**

♪ *Secure Enclave • end-to-end
encryption.*



LAW

The building code

IN THE HOUSE

*The minimum every house must
meet — with penalties.*

THE QUESTION IT ANSWERS

**What must we do, at the very
least?**

♪ *GDPR, CCPA — the floor, not
the ceiling.*



FEATURE

The curtains

IN THE HOUSE

*What the family can see, open,
and close themselves.*

THE QUESTION IT ANSWERS

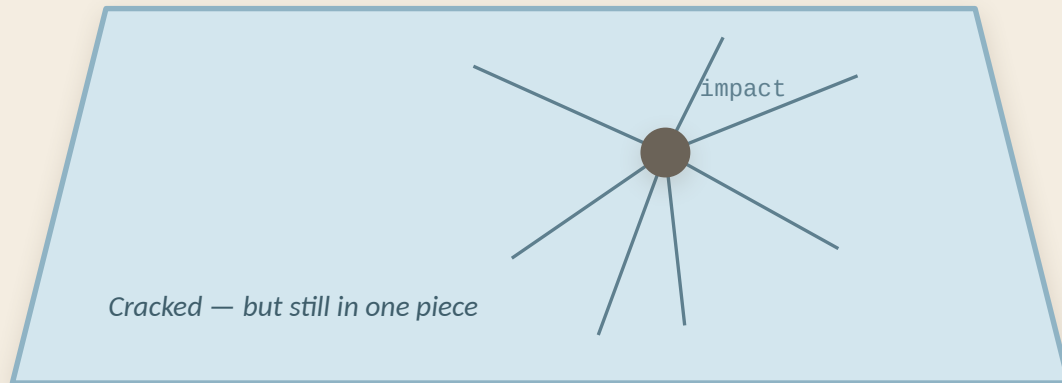
**Can the user see it and change
it?**

♪ *Hide My Email • App Privacy
Report.*

SHORT ANSWER Privacy is the goal. Security keeps it. Law sets the minimum. A feature puts it in the user's hands. You can have security without privacy — a perfectly locked database of everything about everyone — but never privacy without security.

The windshield: privacy decides what a break can do

No design stops every stone. A good one keeps the glass out of the passengers' laps.



OUTER GLASS = SECURITY

Stops most stones before they get through.

PLASTIC INTERLAYER = PRIVACY ENGINEERING

Holds the pieces together when it does crack.

INNER GLASS = DEFAULTS & CONTROLS

The surface the passenger actually touches.

STONE CHIP · A SMALL INCIDENT

A bug writes phone numbers into a debug log.

WITH PRIVACY BY DESIGN

Log kept 7 days, access-restricted, numbers truncated. You repair the chip.

WITHOUT IT

Logs kept forever, copied into analytics. The crack spreads.

ACCIDENT · A MAJOR BREACH

An attacker steals the whole message database.

WITH PRIVACY BY DESIGN

Content end-to-end encrypted, few fields, short retention. They get ciphertext.

WITHOUT IT

Plaintext profiles going back years. Glass in everyone's lap.

SIDE WINDOW · THE OTHER STRATEGY

Side glass shatters into small, blunt cubes on purpose.

WITH PRIVACY BY DESIGN

Aggregates and coarse data: when it breaks, nothing is sharp enough to cut.

WITHOUT IT

Row-level, precise data: every shard can identify someone.

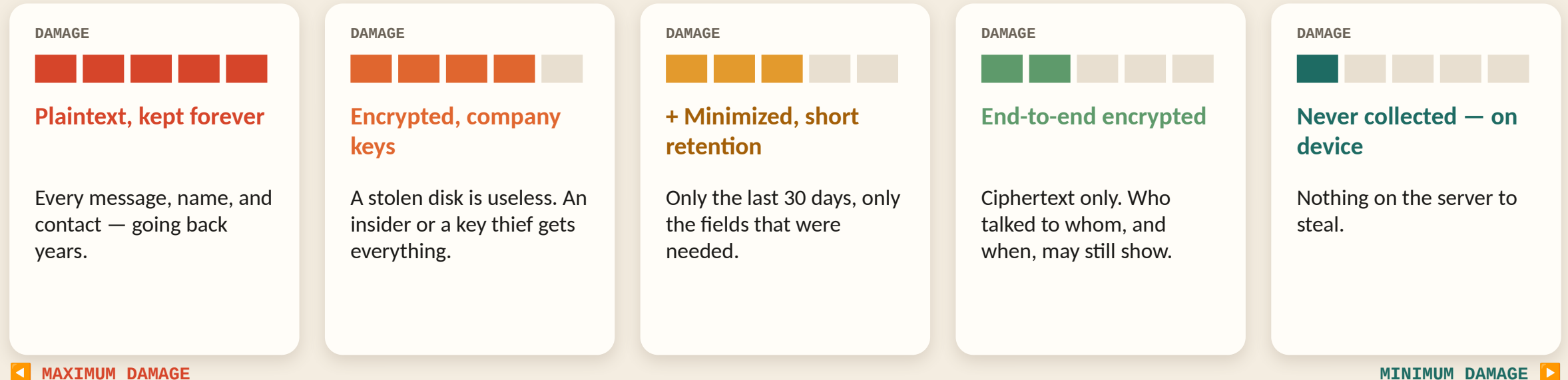
Can privacy prevent the leak? Not always — stopping the stone is security's job. Privacy decides how much the break can hurt.

The breach budget: decide the worst case in advance

You can't promise zero. You can decide, before launch, the most a failure could ever cost.

$$\text{DAMAGE} = \text{WHAT YOU COLLECTED} \times \text{HOW LONG YOU KEPT IT} \times \text{HOW IDENTIFIABLE IT IS} \times \text{WHO HOLDS THE KEY}$$

SAME EVENT, FIVE DESIGNS — “SOMEONE STEALS THE MESSAGE SERVER”



THE FLOOR Even the best design leaves something: metadata, the unlocked phone in your hand, and the person you sent it to.

The expensive safe behind a hackable front door

Security is a chain. Privacy asks the sharper question: what did you leave outside the safe?



FRONT DOOR

Your Apple Account password, device passcode, and the SIM that receives SMS codes.

Hack it and the thief is inside the house.

THE SAFE

Secure Enclave plus end-to-end encrypted data: Keychain, Health, Messages.

Still shut. It needs a key only your devices hold.

THE TABLE

Data that isn't end-to-end encrypted — by default, iCloud Photos, Drive, Notes, backups.

Visible to anyone who gets through the door.

CODE ON THE FRIDGE

A recovery key saved in Notes; a passcode someone watched you type.

The safe is only as strong as where you keep its code.

APPLE'S ANSWERS

Stolen Device Protection

A watched passcode alone can't take your account.

Security keys & passkeys

A front door that can't be phished.

Advanced Data Protection

Moves the table into the safe.

Delete, unsend, remove the app, wipe the phone

Four buttons that feel the same. They reach very different copies of your message.



DELETE

- Gone from the conversation. With Messages in iCloud on, the delete syncs to your iPad and Mac too.
- Waits in Recently Deleted for up to 30 days, then it's gone for good.
- The recipient's copy is untouched.

♪ Deleted everywhere you're signed in — not on their phone.



UNSEND

- Only for iMessage, and only within 2 minutes. It disappears from their device too; both see "You unsent a message."
- On older software, they may still see it.
- Whatever they already read, screenshotted, or saw in a notification stays with them.

♪ Undo Send pulls it back — if you're quick and they're current.



REMOVE THE APP

- Messages is built into iOS — you can't delete it. Turning off iMessage or signing out leaves your history on the phone and in iCloud.
- True for every app: deleting it clears the device, not the company's cloud.

♪ Removing the app is not deleting the data.



WIPE THE PHONE

- Erase All Content and Settings destroys the encryption keys, so everything on that iPhone is unreadable at once.
- Your iCloud copy, your Mac, and the recipient keep theirs. Restore from a backup and it all comes back.

♪ Destroy the key, and the data is gone — on that device.

Where does the message still live?

Deletion is local. Copies are distributed. A privacy engineer's first question is always: where are all the copies?

	THIS iPhone	YOUR MAC & iPad	iCloud	THEIR DEVICES
Delete	~ gone after 30 days	✓ synced delete	✓ synced delete	✗ untouched
Unsend	✓ gone	✓ gone	✓ gone	~ only if current & within 2 min
Remove app	✗ history stays	✗ stays	✗ stays	✗ untouched
Wipe iPhone	✓ keys destroyed	✗ stays	✗ restores it	✗ untouched

NO BUTTON REACHES screenshots · forwards · notifications already seen · an old iCloud Backup* · the other person's memory

♪ *Messages is end-to-end encrypted — wherever the copies live, Apple can't read them.*

THE ENGINEER'S VERSION

Delete

Soft delete with a recovery window, then purge.

Unsend

A recall request to other parties — best effort, never a guarantee.

Remove app

Uninstalling the client never deletes the server copy.

Wipe

Crypto-shredding: destroy the key, not every byte.

Deletion fan-out in a real system → p. 30

Five failures every privacy engineer should know

Each one broke a different assumption. Learn the assumption, not just the headline.

CASE FILES

2006

AOL search logs

WHAT HAPPENED

Released “anonymized” search logs keyed by user number. Reporters identified a real person from her queries alone.

BROKEN ASSUMPTION

“Removing names makes data anonymous.”

2006–08

Netflix Prize

WHAT HAPPENED

Researchers re-identified subscribers by matching “anonymous” movie ratings against public IMDb reviews.

BROKEN ASSUMPTION

“Data nobody else has is safe to publish.”

2012

Retail inference

WHAT HAPPENED

A retailer’s purchase model predicted pregnancy — reportedly before a customer’s family knew.

BROKEN ASSUMPTION

“We only use what customers gave us.”

2018

Fitness heatmap

WHAT HAPPENED

A global activity heatmap outlined the layout of sensitive military sites around the world.

BROKEN ASSUMPTION

“Aggregates can't reveal anything sensitive.”

2018

Cambridge Analytica

WHAT HAPPENED

A quiz app used friend permissions to harvest data on tens of millions who never used it.

BROKEN ASSUMPTION

“One user's consent covers their friends.”

Build the foundations.

Learn to see data, identity, purpose, time, and harm — before reaching for any privacy technology.

IN THIS LEVEL



Personal data is bigger than names and emails

Think about anything that can identify, describe, locate, infer, or link a person.



DIRECT

**name • email • phone •
account ID**

Identifies a person on its own.



DEVICE

**IP • device IDs • cookies • ad
IDs**

*Follows a person across apps and
sites.*



BEHAVIOR

**clicks • searches • views •
dwell time**

Reveals interests and intent.



LOCATION

**GPS • Wi-Fi • IP-geo • check-
ins**

*A handful of points reveals home
and work.*



TRANSACTION

**purchases • payments •
balances**

*Regulated in many places; high
fraud value.*



INFERRED

**interests • risk scores •
segments**

*You created it — you still own the
risk.*

Review rule: data that looks harmless alone can become sensitive once it is linked.

Three boring fields can name you

Quasi-identifiers are harmless alone and identifying together. They are why “we removed the names” fails.

87%

of the U.S. population was likely uniquely identifiable by just these three fields.

— Latanya Sweeney, 2000



WHY IT MATTERS

Any dataset with these columns can be joined to voter rolls, public records, or a leaked file — and names come right back.

OTHER COMMON QIS

job title + employer · rare diagnosis + city ·
timestamps + location · device model +
timezone + language

DEFENSES

Generalize (ZIP → 3 digits, DOB → year),
suppress rare combinations, or never
release row-level data at all.

Not all personal data carries the same risk

Tier the data first. The tier decides the default controls — so reviewers debate exceptions, not basics.

TIER	EXAMPLES	DEFAULT CONTROLS
T0 · PUBLIC	Published prices, public profile fields	Integrity checks; no special handling
T1 · INTERNAL	Aggregate metrics, config, non-personal logs	Access control; standard retention
T2 · PERSONAL	Email, device ID, usage events	Purpose tags, retention limits, access logging
T3 · SENSITIVE	Precise location, contacts, messages, financial data	Minimize, encrypt, need-to-know access, short TTL
T4 · SPECIAL	Health, biometrics, children's data, sexual orientation, government IDs	Avoid collecting; on-device first; explicit consent; strongest isolation

Privacy follows the data from collection to deletion

A good review asks one question — and names one control — at every stage.



COLLECT

What?

CONTROL

Collect the minimum;
derive on device
where you can.



PROCESS

Where?

CONTROL

Process locally or
inside isolated
services.

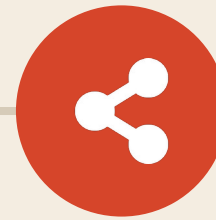


USE

Why?

CONTROL

Purpose tags checked
at read time, not just
intake.



SHARE

With whom?

CONTROL

Contracts, scoped
tokens, aggregation
before export.



STORE

How long?

CONTROL

TTL per field: raw →
derived → aggregate.



DELETE

Prove it.

CONTROL

Propagated deletes,
audit trail, verification
scans.

The deletion path is part of the architecture — not a ticket you file after launch.

What can a privacy failure actually do?

Think in human consequences, not data categories. Name the harm and the fix gets obvious.



SURVEILLANCE

Someone observes behavior people expected to stay private.

e.g. A “find friends” feature that keeps a history nobody asked for.



EXPOSURE

Sensitive information becomes visible to the wrong party.

e.g. A lock-screen preview reveals a diagnosis on a shared phone.



LINKABILITY

Separate activities get stitched into a person-level history.

e.g. One ad ID shared by a health app and a dating app.



MANIPULATION

Profiles are used to steer, exploit, or discriminate.

e.g. Prices that rise for users inferred to be desperate.



LOSS OF CONTROL

People can't understand, stop, correct, or delete a use.

e.g. Opt-out honored in the app, ignored in the warehouse.



SECONDARY USE

Data collected for one reason quietly serves another.

e.g. Phone numbers given for security reused for ad targeting.

The seven foundational principles

Ann Cavoukian's framework (2009) — now echoed in GDPR Article 25, “data protection by design and by default.”

1

Proactive, not reactive

Find the exposure in the design review, not the incident review.

2

Privacy as the default

The user does nothing — and is still protected.

3

Embedded into design

A property of the architecture, not a bolt-on filter.

4

Full functionality

Positive-sum: ship the feature and the protection.

5

End-to-end security

Protect data from collection to verified deletion.

6

Visibility & transparency

Claims can be checked by users, auditors, researchers.

7

Respect for the user

Strong defaults, clear notice, easy controls.

ENGINEER'S TRANSLATION

*Turn each principle
into a check a machine
can run. A principle
nobody tests is a poster.*

What each law asks of engineers

You don't need to be a lawyer. You need to know which obligations turn into system requirements.

GDPR

EU / EEA · 2018

Personal data of people in the EU.

Lawful basis per purpose · access, erasure, portability · DPIAs for high-risk processing · 72-hour breach notice to regulators.

CCPA / CPRA

California

Consumers' personal information at covered businesses.

Know, delete, correct · opt out of sale and sharing · limit use of sensitive PI · honor Global Privacy Control.

COPPA

United States

Children under 13 on child-directed services.

Verifiable parental consent · strict minimization · deletion on request · no behavioral ads without consent.

HIPAA

United States

Health data at covered entities and business associates.

Minimum-necessary access · audit controls · business associate agreements · breach notification.

GLBA

United States

Customer data at financial institutions.

Privacy notices · opt-outs for some sharing · a written security program under the Safeguards Rule.

PCI DSS

Card-industry standard

Payment card data wherever it is stored or processed.

Don't store what you don't need · tokenize card numbers · segment the card environment · never keep CVV after auth.

Every user right is a system requirement in disguise

When a user asks, the system must answer across every store — including the ones nobody remembers.

Access · “right to know”



Find every record for a person across services, warehouse, logs, and backups — by identity graph, not guesswork.

Deletion · erasure



Propagate deletes to replicas, caches, derived tables, ML features, and vendors — and prove completion.

Correction



Fix the source and every downstream copy so stale derivatives cannot resurrect old values.

Portability



Export in a machine-readable format, behind authentication strong enough to stop account takeover.

Opt-out · objection



Check consent at read time, not only at collection — and honor it inside batch jobs too.

Limit sensitive use



Purpose tags on sensitive fields, enforced by the query layer rather than a wiki page.

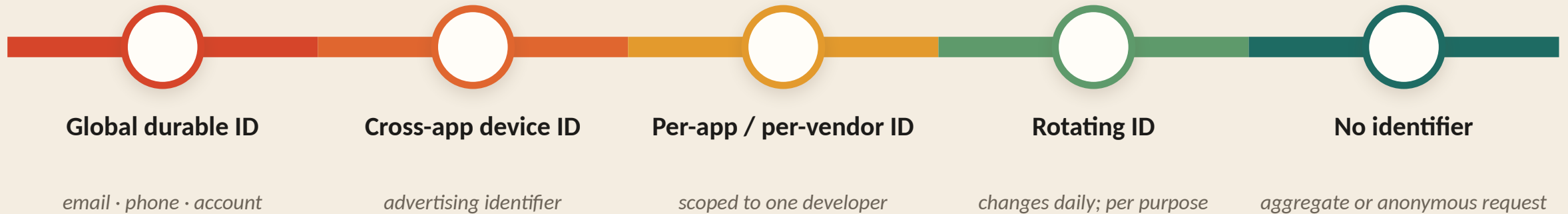
The hard prerequisite behind all six: data lineage. You cannot delete what you cannot find.

Identifiers create linkability

Every stable key is a thread that stitches contexts together. Choose the weakest identifier that still does the job.

◀ MORE LINKABLE

LESS LINKABLE ▶



ASK IN EVERY REVIEW

Can we use a rotating, scoped, or purpose-specific identifier instead of one durable identity?

THE APPLE PATTERN

Per-vendor identifiers for apps, App Tracking Transparency gating the advertising identifier, and iCloud Private Relay hiding IP addresses from sites.

Permission is not a blank check

Data should carry its purpose with it — and every new use should have to show its ticket.

A PURPOSE TAG TRAVELS WITH THE DATA



1

What did the user understand?

Not what the policy says — what a reasonable person took away.

2

What was the original purpose?

Recorded in metadata, not in someone's memory.

3

Did the purpose change?

A new purpose needs a new basis — often new consent.

4

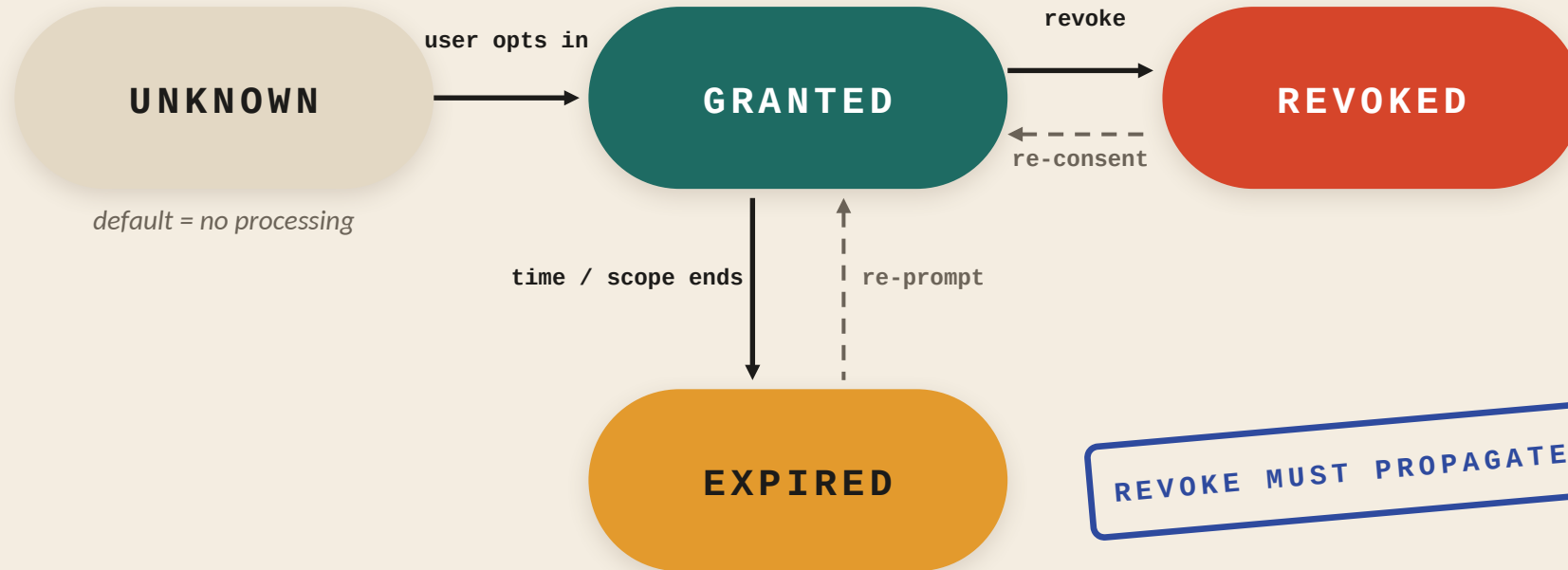
Can the user revoke?

And does revocation reach every copy?

Consent is one control. Architecture should still minimize exposure — and enforce purpose at read time.

Consent is state, not a checkbox

Model it explicitly. Every state change must reach every copy of the data — including the ones in flight.



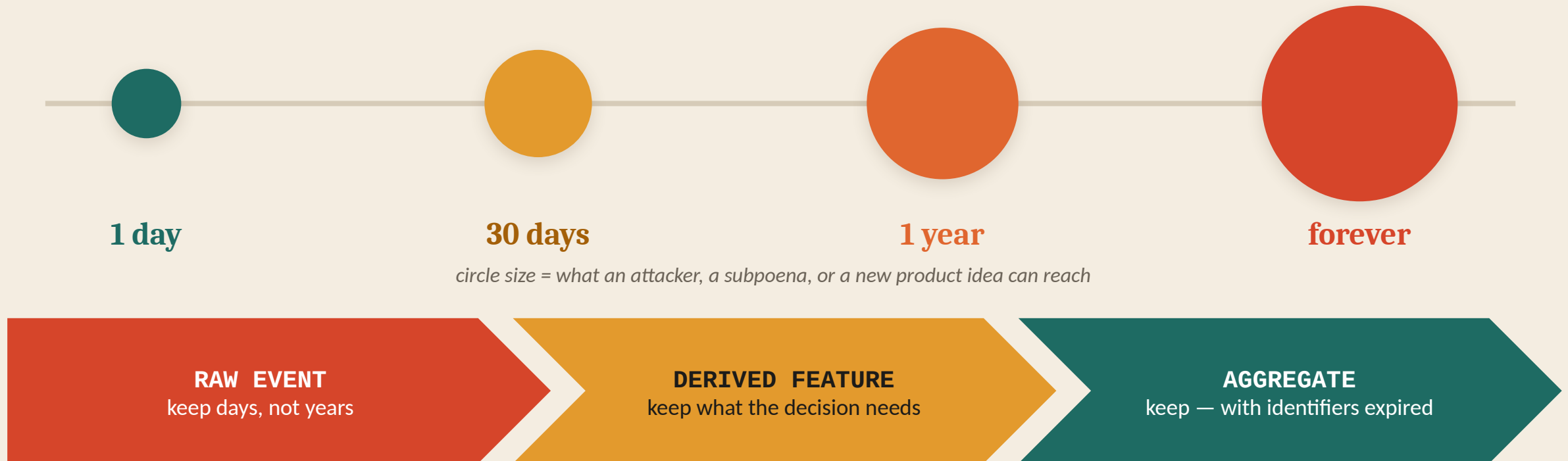
ON REVOKE, THE SYSTEM MUST

- 1 Stop new collection
- 2 Filter reads at query time
- 3 Purge or detach derived data
- 4 Tell downstream jobs & vendors
- 5 Log it for audit

Where it breaks in practice: batch jobs that cached consent at start, features built before revocation, exports already sent.

Retention is a risk multiplier

Every extra day is another day for breach, subpoena, misuse, inference, and scope creep.



The question to ask: after the decision is made, do we still need the raw event?

Pseudonymous is not anonymous

Removing a name does not remove identifiability. Know exactly where your data sits on this spectrum.

IDENTIFIED

```
name: Jane Doe  
email: jane@mail.com  
zip: 94086
```

Directly names a person.

RE-ID RISK



PSEUDONYMIZED

```
uid: u_8472  
zip: 94086  
dob: 1988-03-14
```

Re-linkable. Still personal data under GDPR.

RE-ID RISK



DE-IDENTIFIED

```
uid: -  
zip: 940**  
age: 35-39
```

Risk reduced, not removed.

RE-ID RISK



ANONYMIZED

```
zip3: 940  
age: 30-39  
(k ≥ 20)
```

No reasonably likely route back. Hard.

RE-ID RISK



AGGREGATE + DP

```
zip3: 940  
count: 1,204  
± noise (ε = 1)
```

Provable bound. Least granular.

RE-ID RISK



Linkage attack: join “anonymous” data to a public dataset on shared quasi-identifiers — exactly how AOL and Netflix failed.

The test: could a motivated insider with outside data single out one person? If yes, it is not anonymous.

Encryption, tokenization, isolation

Three ways to protect value without carrying the original everywhere — each with a blind spot.



ENCRYPT

Same data, unreadable without the key.

STOPS

Disk theft, network sniffing, a stolen backup.

DOESN'T STOP

Anyone the system decrypts for — including over-broad internal access.



TOKENIZE

Swap the sensitive value for a surrogate; keep the original in a vault.

STOPS

Card numbers and IDs spreading into logs, analytics, and vendors.

DOESN'T STOP

Linkability — a stable token is still a stable identifier.



ISOLATE

Separate identity from behavior across systems, keys, and teams.

STOPS

One compromised service revealing who did what.

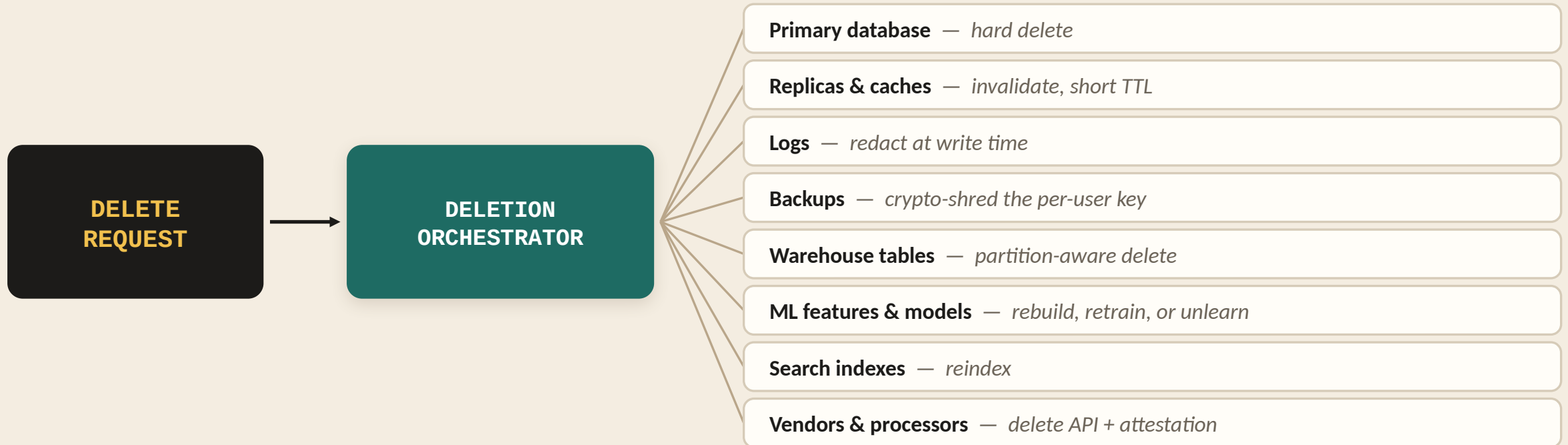
DOESN'T STOP

A join someone is permitted to run. Guard the join path.

Encryption protects necessary data. Minimization asks whether the data should exist at all.

Deletion is a distributed-systems problem

One “delete my account” fans out to every place the data was ever copied. Miss one and the promise breaks.



Tombstones

Mark deleted so late-arriving copies can't resurrect the record.

Crypto-shredding

Encrypt per user; destroy the key to delete everywhere at once.

Verification

Re-query after the SLA; alert on any survivor.

Now engineer the privacy promise.

Choose controls from the data flow and the threat model — never because a technique sounds impressive.

IN THIS LEVEL



Privacy-enhancing technologies, sorted by what they change

No single technique solves every problem. Group them by the question each one answers.

REDUCE THE DATA

- **Minimization**
collect fewer fields
- **On-device processing**
raw data never leaves
- **Retention limits**
shrink time-at-risk
- **Generalization**
coarsen ZIP, age, timestamps

TRANSFORM THE DATA

- **Pseudonymization**
swap identifiers for surrogates
- **k-anonymity family**
hide each row in a crowd of k
- **Differential privacy**
provable bound on one person's influence
- **Synthetic data**
statistically similar fake rows

PROTECT THE COMPUTATION

- **Federated learning + secure agg.**
train without collecting
- **Secure multi-party computation**
compute jointly, reveal only output
- **Homomorphic encryption**
compute on ciphertext
- **TEEs / confidential compute**
hardware-isolated processing

Expert habit: state the threat model before naming the technology.

The one-sentence version

Whatever you publish should look almost the same whether or not any one person is in the data.



Two datasets that differ by exactly one person's records

Outputs remain statistically similar

Calibrated noise limits how much any one person can move the result — so the output can't reveal whether you were in it.

ϵ (epsilon) is the privacy-loss budget. Smaller $\epsilon \rightarrow$ stronger privacy $\rightarrow$ more noise $\rightarrow$ less accuracy.

DP DEFENDS AGAINST

membership inference · linkage with outside data · differencing attacks
— no matter what the attacker already knows.

DP DOES NOT HIDE

population-level truths (“people in this ZIP tend to...”) — that is the point of the analysis, not a leak of you.

The Laplace mechanism on one slide

Add noise scaled to how much one person can change the answer (Δ), divided by ϵ .

```
# counting query: one person changes it by at most 1
def private_count(rows, epsilon):
    true = len(rows)
    b = 1.0 / epsilon      # scale =  $\Delta / \epsilon$ 
    return true + laplace(0, b)

private_count(users_in_zip, 1.0)  # error ~  $\pm 1$ 
private_count(users_in_zip, 0.1)  # error ~  $\pm 10$ 
```

Δ SENSITIVITY

Max change one person can cause. Bound it by clipping each person's contribution.

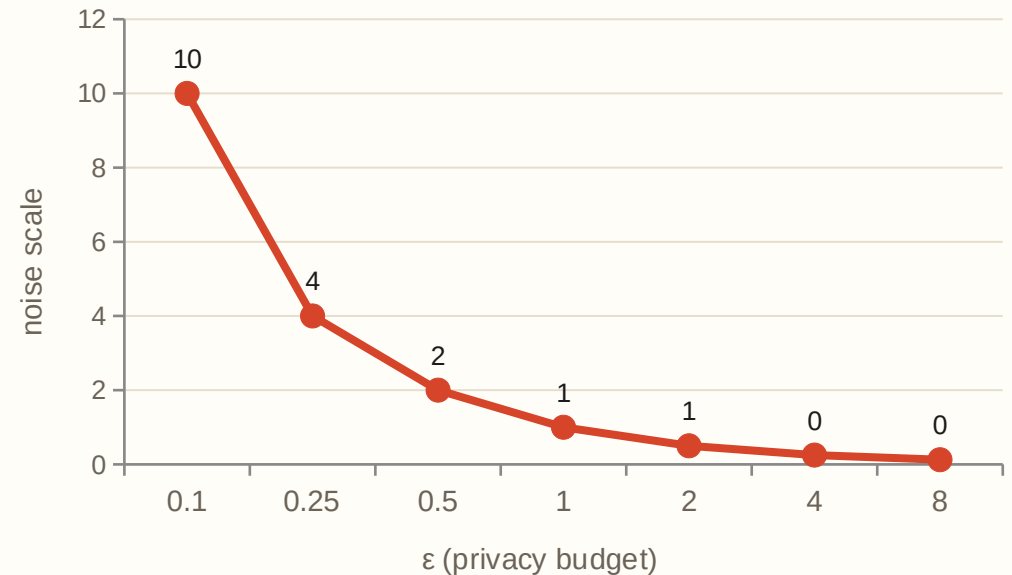
ϵ EPSILON

Privacy loss. Always ask “ ϵ per what — per query, per day, per user?”

δ DELTA

Small chance the guarantee fails (“approximate DP”). Keep it far below $1/n$.

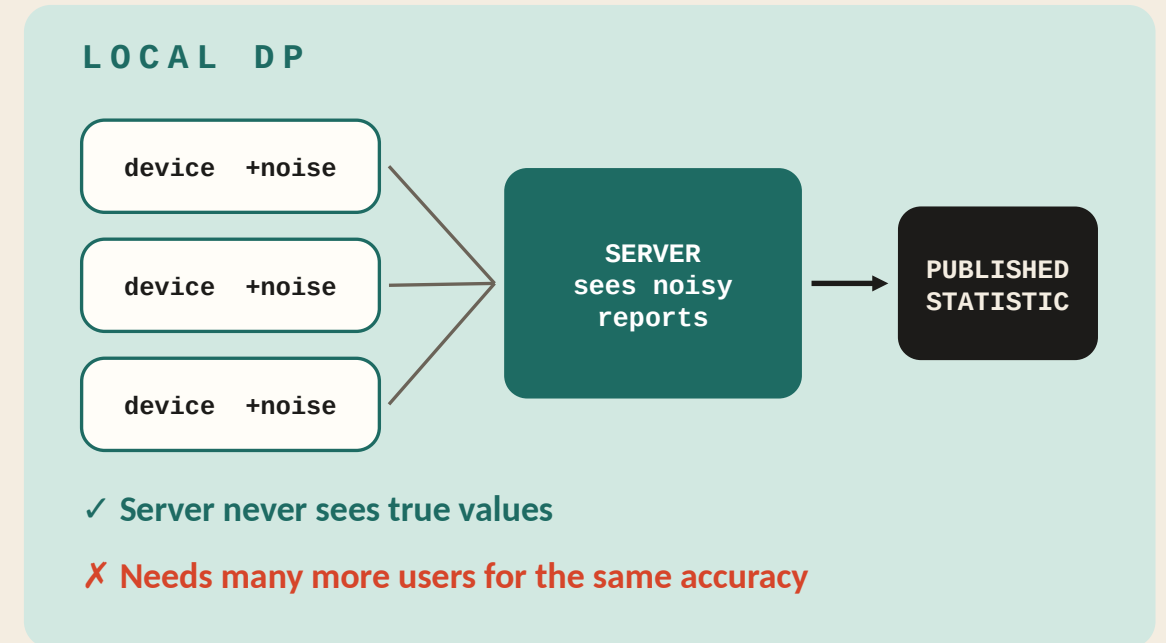
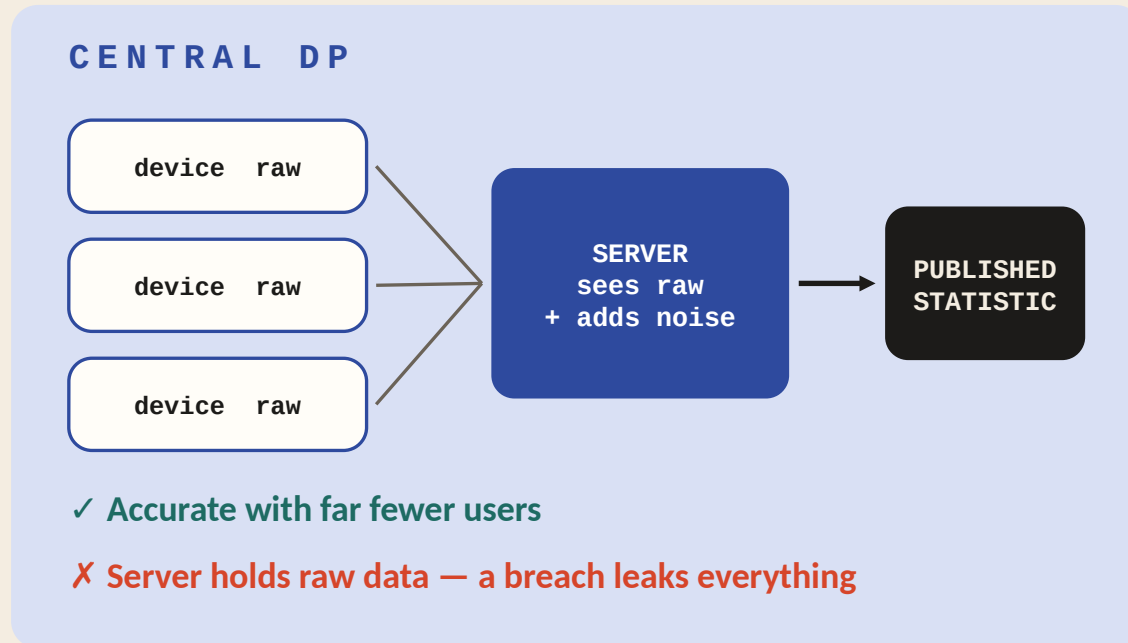
Noise scale $b = \Delta / \epsilon$ ($\Delta = 1$)



Stronger privacy costs accuracy fast below $\epsilon = 1$.

Where does the noise get added?

Central DP trusts the collector with raw data. Local DP does not — which is why Apple privatizes on the device.



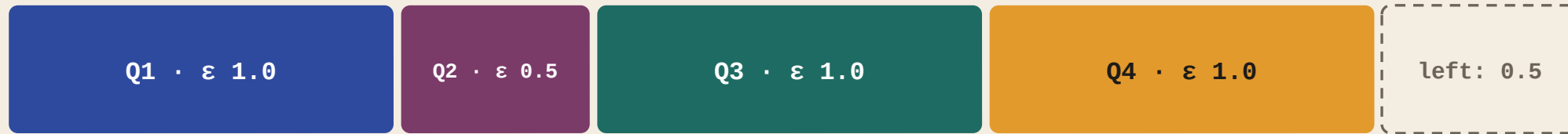
Also know the shuffle model: reports are anonymized and shuffled before analysis — recovering accuracy with less trust.

Apple's deployment: local DP with sketching algorithms to learn popular emoji, new words, and problem websites in Safari.

Privacy budgets compose — every query spends

Answer k queries at ϵ each and, under basic composition, you have spent up to $k \cdot \epsilon$. Without accounting, “private” quietly isn’t.

TOTAL BUDGET $\epsilon = 4.0$



A ledger that refuses the query is a feature, not an outage.

Q5 asks for $\epsilon 1.0$

DENIED



Keep a ledger

Track spend per dataset — and per person where the design allows.



Cap contributions

Limit how many records one person adds per period; it bounds Δ .



Use tighter accounting

Advanced composition or Rényi-DP accountants beat plain $k \cdot \epsilon$ for many queries.



Reuse answers

Cache released results; asking the same question again spends budget again.

k-anonymity — and why it wasn't enough

Make every record indistinguishable from at least $k-1$ others on its quasi-identifiers. Then watch the sensitive column.

ZIP	AGE	SEX	DIAGNOSIS (sensitive)
940**	30-39	F	Flu
940**	30-39	F	Asthma
940**	30-39	F	Flu
941**	40-49	M	Heart disease
941**	40-49	M	Heart disease
941**	40-49	M	Heart disease

$k = 3$

k - ANONYMITY

Each quasi-identifier combination appears at least k times.
Defeats simple linkage.

l - DIVERSITY

Each group holds at least l distinct sensitive values. Defeats the homogeneity attack at left.

t - CLOSENESS

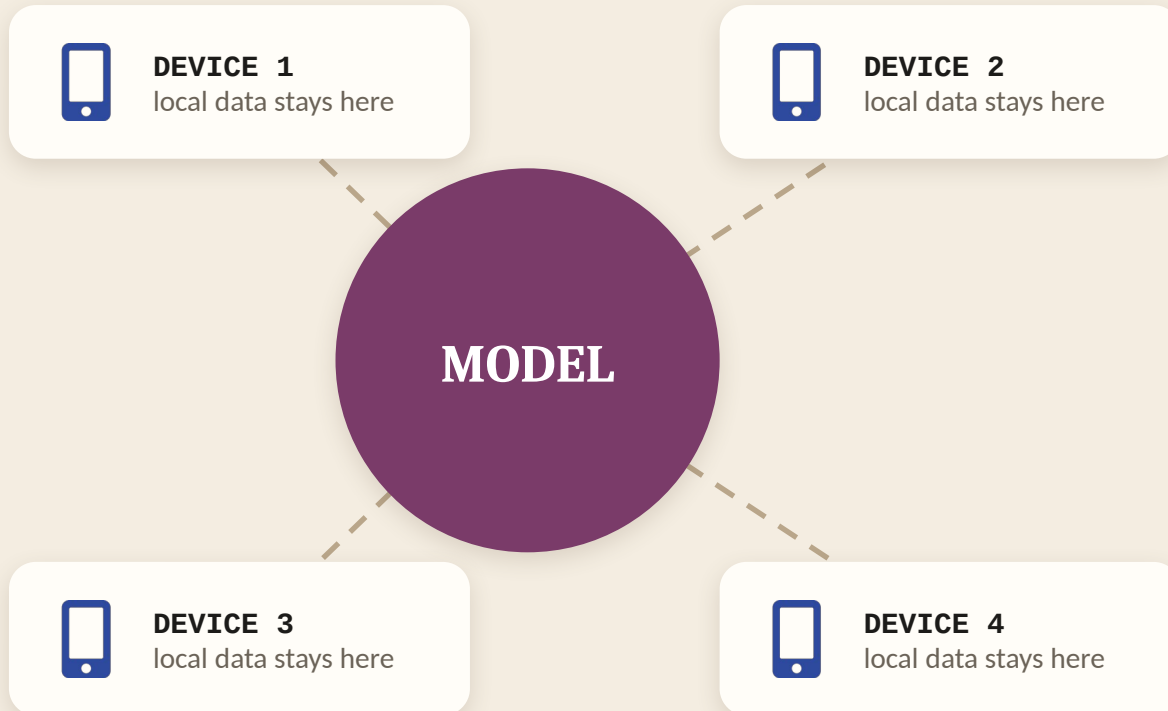
Each group's sensitive distribution stays close to the overall one.
Limits skew-based inference.

$k = 3$ ✓ DIAGNOSIS LEAKED ✗

Why DP won: k-anonymity describes one release and breaks under composition and background knowledge. DP's guarantee holds regardless.

Move training to the data — then add layers

Devices train locally and send updates, not raw data. Updates can still leak, so stack defenses.



THE LAYERED DEFENSE

- 1 Federated learning**
Raw data stays on the device; only model updates travel.
- 2 Secure aggregation**
The server sees only the sum of many updates, never one.
- 3 Differential privacy**
Clip and noise updates to bound any one person's influence.
- 4 Cohort minimums + deletion**
Require many participants; discard updates after aggregating.

Local updates can still leak — gradient inversion and membership inference are real attacks.

When parties must compute, but no one should see

The heavy PETs: powerful, expensive, and worth knowing exactly when to reach for.



MPC

Secure multi-party computation

IDEA

Parties split secrets into shares and compute jointly; only the output is revealed.

USE WHEN

Two companies want an overlap count without sharing their lists.

COST



Network-heavy; complex protocols



HE

Homomorphic encryption

IDEA

Compute directly on encrypted data; only the key holder can read the result.

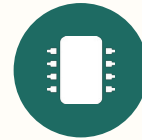
USE WHEN

A server must score data it must never be able to read.

COST



Often orders of magnitude slower



TEE

Trusted execution / confidential compute

IDEA

Hardware-isolated code the host can't inspect; attestation proves what is running.

USE WHEN

Cloud processing of sensitive data with verifiable code.

COST



Trust the chip vendor; side channels



PSI

Private set intersection

IDEA

Learn which items two sets share — and nothing else about either set.

USE WHEN

Contact discovery; compromised-password checks.

COST



The intersection itself still leaks

Who are you protecting the user from?

Different adversaries imply different controls. Name the adversary before you name the fix.



OUTSIDER

breach • theft

Encryption, isolation, and minimal stored data.



PARTNER

over-collection • reuse

Contracts, scoped APIs, aggregation, audits.



INSIDER

excess or curious access

Need-to-know, access logs, break-glass review.



TRACKER

cross-context linkability

Partitioning, rotating IDs, fingerprinting defenses.



FUTURE YOU

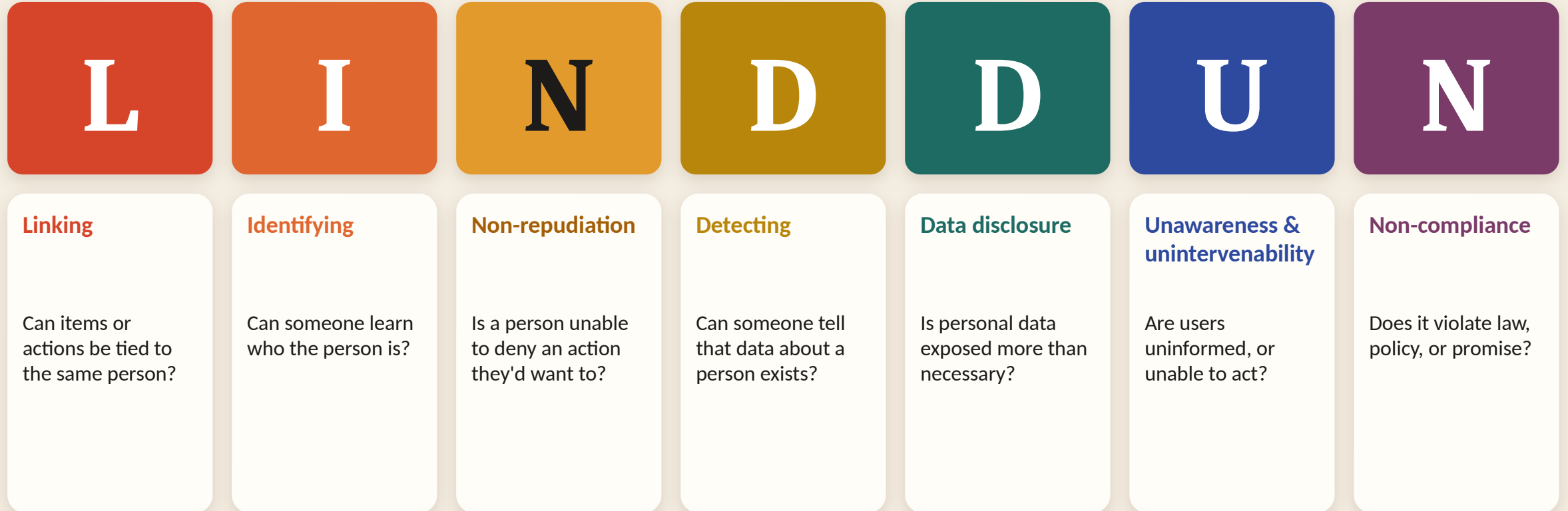
retention • scope creep

TTLs, purpose enforcement, deletion by default.

The privacy question: what can an actor learn or infer — even if the system behaves exactly as designed?

LINDDUN: the STRIDE of privacy

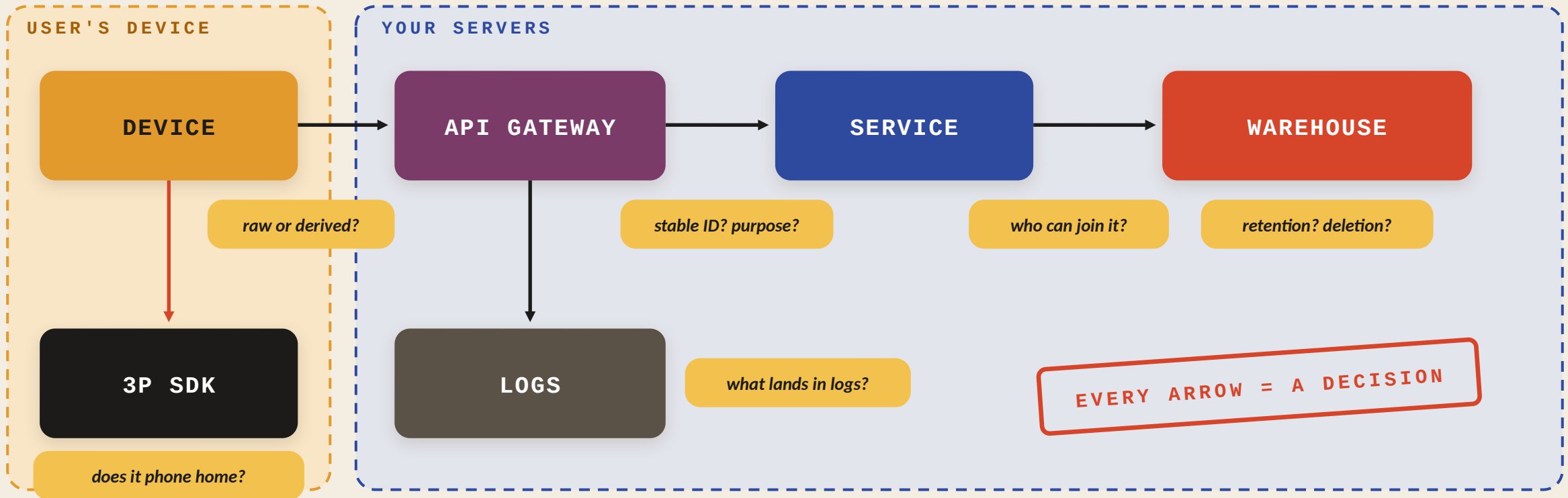
A threat-modeling framework from KU Leuven. Walk every category across every element of your data-flow diagram.



Pair it with STRIDE for security — and be ready to say which threat each proposed control actually addresses.

Draw the data flow before debating policy

A simple diagram exposes the real problem. Mark the trust boundaries — that is where privacy failures live.



Every arrow is a chance to minimize, transform, isolate, aggregate, or delete.

The 8-question privacy review

Works on any feature — even one you have never seen. Each question comes with the red flag to listen for.

1 VALUE

What customer outcome needs data?

RED FLAG “We might need it later.”

2 DATA

Exactly what enters the system?

RED FLAG Free text, full URLs, raw payloads.

3 IDENTITY

Can it be linked to a person?

RED FLAG A durable ID shared across features.

4 FLOW

Where does it travel?

RED FLAG Unlisted SDKs, logs, exports.

5 ACCESS

Who can see or join it?

RED FLAG Warehouse-wide read by default.

6 TIME

How long does raw data remain?

RED FLAG No TTL, or “until deleted.”

7 MISUSE

What secondary use is possible?

RED FLAG Security data readable by ads.

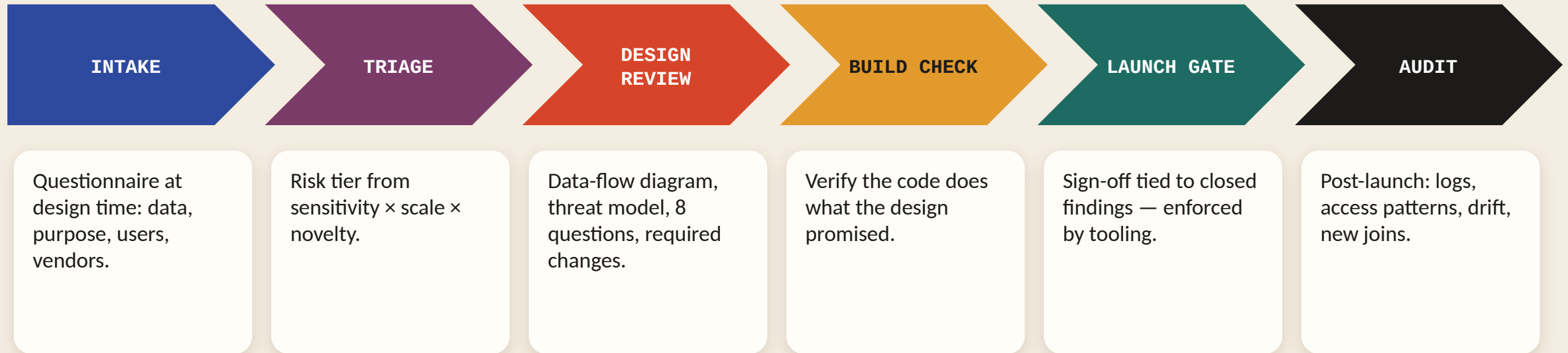
8 REDUCE

What can we remove or enforce?

RED FLAG Controls that live only in a doc.

How a privacy review actually runs inside a company

Reviews scale only when most launches are low-risk and self-serve. Spend expert time where the risk is.



MATCH EFFORT TO RISK

LOW → self-serve checklist + automated checks

MEDIUM → asynchronous expert review

HIGH → full review, threat model, exec sign-off

Privacy bugs are usually assumption bugs

The design said one thing. The code, the logs, and the edge cases said another.

SPEC

What should happen?

≠

IMPLEMENTATION

What actually happens?

≠

ABUSE / EDGE

What else can happen?

TEST THESE EVERY TIME



Revocation mid-job

batch started before the opt-out



Retries & dead letters

payload copies nobody deletes



Debug logging

the #1 place raw data leaks



Fallback paths

degraded mode skips the filter



Exports

a CSV escapes every control



Shared devices

notifications reveal to others



Stale consent

cached at login, never refreshed



Partial failures

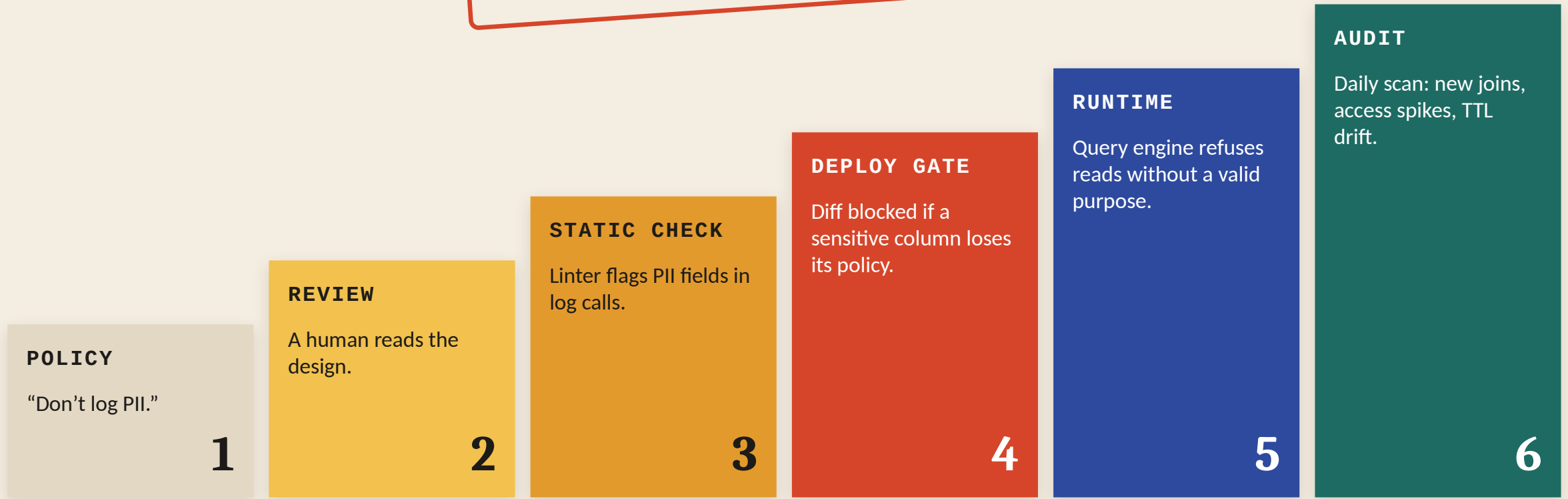
half the deletes succeeded

Move controls from documents into machines

Every rung up is harder to build and harder to bypass. Rule of thumb: every hard gate should trace back to a real postmortem.

EASY TO WRITE,
EASY TO IGNORE

THE GAP: PRE-DEPLOY $\neq$ RUNTIME



Browser suggestions without a browsing diary

Start with the product goal, then shrink the data until it hurts — and stop just before that.

DESIGN A · SERVER-FIRST

Upload full URL + user ID → server keeps history → server ranks suggestions.

EXPOSURE



DESIGN B · ON-DEVICE FIRST

Rank from local history on the device → send only privatized, thresholded domain counts to learn what is popular.

EXPOSURE



RECOMMEND B

QUESTIONS THAT SHRINK THE DATA

Need the full URL?

Strip query params & fragments?

Need identity at all?

Threshold rare domains?

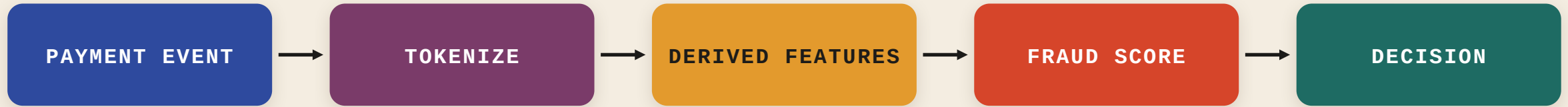
Local DP on the counts?

Keep raw data how long?

Strong answer: “My first question is whether the server needs a browsing-history database at all.”

Payments fraud: keep the signal, shed the identity

The goal is not zero data. It is the minimum necessary data, with strong separation.



PRIVACY QUESTIONS

- Tokenize card and account identifiers at ingestion
- Keep identity in a separate, audited vault
- Limit feature history to bounded windows
- Investigation access: case-based, logged, time-boxed

PRODUCT QUESTIONS

- Which signals actually move precision and recall?
- What fraud loss does each removal cost?
- Can we A/B the privacy change and measure it?
- What must we keep for disputes and regulators?

Expert move: separate fraud investigation (rare, audited, identity-bearing) from model training (bulk, tokenized, time-boxed).

Summarize my inbox with cloud AI

The newest design question in the building: how do you use large models on the most personal data there is?



Can it run on the device?

Yes → run it there. Nothing leaves.

no ↓



If not: can the cloud be stateless and verifiable?

Yes → attested nodes, no retention, no privileged access, inspectable builds.

no ↓



What still has to leave?

Send only the needed messages; strip attachments; never train on it.

REQUIREMENTS TO STATE OUT LOUD

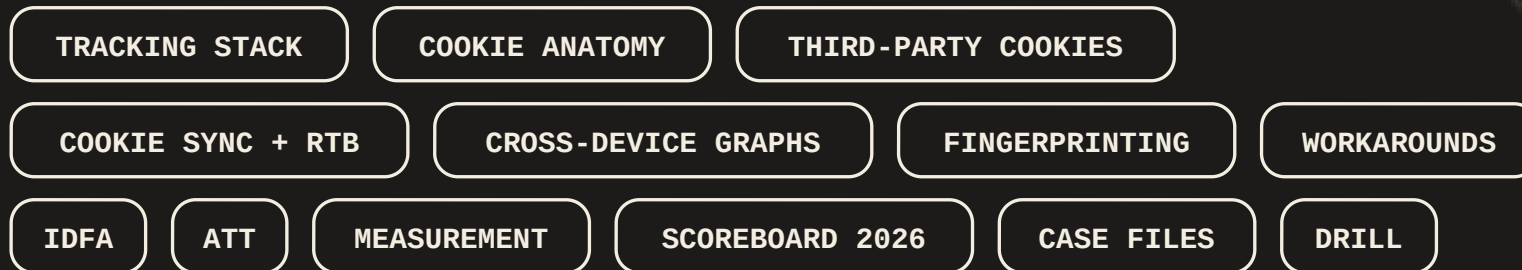
- ✓ No retention after the response
- ✓ No use for model training
- ✓ No privileged runtime access for staff
- ✓ Verifiable software images
- ✓ Requests routed so no user can be targeted
- ✓ A visible indicator and an off switch

PCC's published goals: stateless computation • enforceable guarantees • no privileged runtime access • non-targetability • verifiable transparency.

Meet the monster: the tracking machine.

Cookies, device IDs, fingerprints and identity graphs — how one person gets stitched together across every site, app, and screen.

IN THIS MODULE



Eight ways to say “it’s the same person again”

A reviewer should be able to name every one — and the control that answers it.



COOKIES & STORAGE

A random ID saved in the browser and read back on every visit.

COUNTERED BY *partitioning · 3P blocking · expiry caps*



DEVICE AD IDs

IDFA on iOS, GAID on Android: one ID shared by every app on the phone.

COUNTERED BY *ATT prompt · zeroed IDs · per-vendor IDs*



FINGERPRINTS

Fonts, GPU, screen, audio and time zone combined into a stable signature.

COUNTERED BY *noise · uniform values · blocking*



LOGIN & HASHED EMAIL

The same email, hashed, becomes the same key on every site you sign in to.

COUNTERED BY *relay addresses · consent*



IP ADDRESS

Shared by a household and stable for days — a free cross-device join key.

COUNTERED BY *Private Relay · coarsening*



LINK DECORATION

Click IDs appended to URLs carry identity from one site to the next.

COUNTERED BY *stripping known parameters*



SDKs & PIXELS

Third-party code inside apps and pages that reports events back home.

COUNTERED BY *SDK inventory · privacy manifests*



SERVER-SIDE

Events forwarded server-to-server, invisible to every browser defense.

COUNTERED BY *consent at source · contracts · audits*

Every cookie attribute is a privacy decision

A cookie is a name, a value, and rules about who gets it back. The rules are where the privacy lives.

```
HTTP/1.1 200 OK
Set-Cookie: uid=8f3a91c2e7;
  Domain=.tracker.example;
  Path=/;
  Max-Age=34560000;
  Secure; HttpOnly;
  SameSite=None;
  Partitioned
```

FIRST-PARTY

Set by the site in your address bar. Remembers you on that one site.

THIRD-PARTY

Set by a domain embedded in the page. Recognizes you on every site that embeds it.

Domain

Which sites get the cookie back. A leading dot shares it with every subdomain.

Max-Age

34,560,000 seconds is 400 days — the longest Chrome allows. Lifetime is exposure time.

Secure · HttpOnly

Security, not privacy: HTTPS only, hidden from page scripts. The ID still travels.

SameSite=None

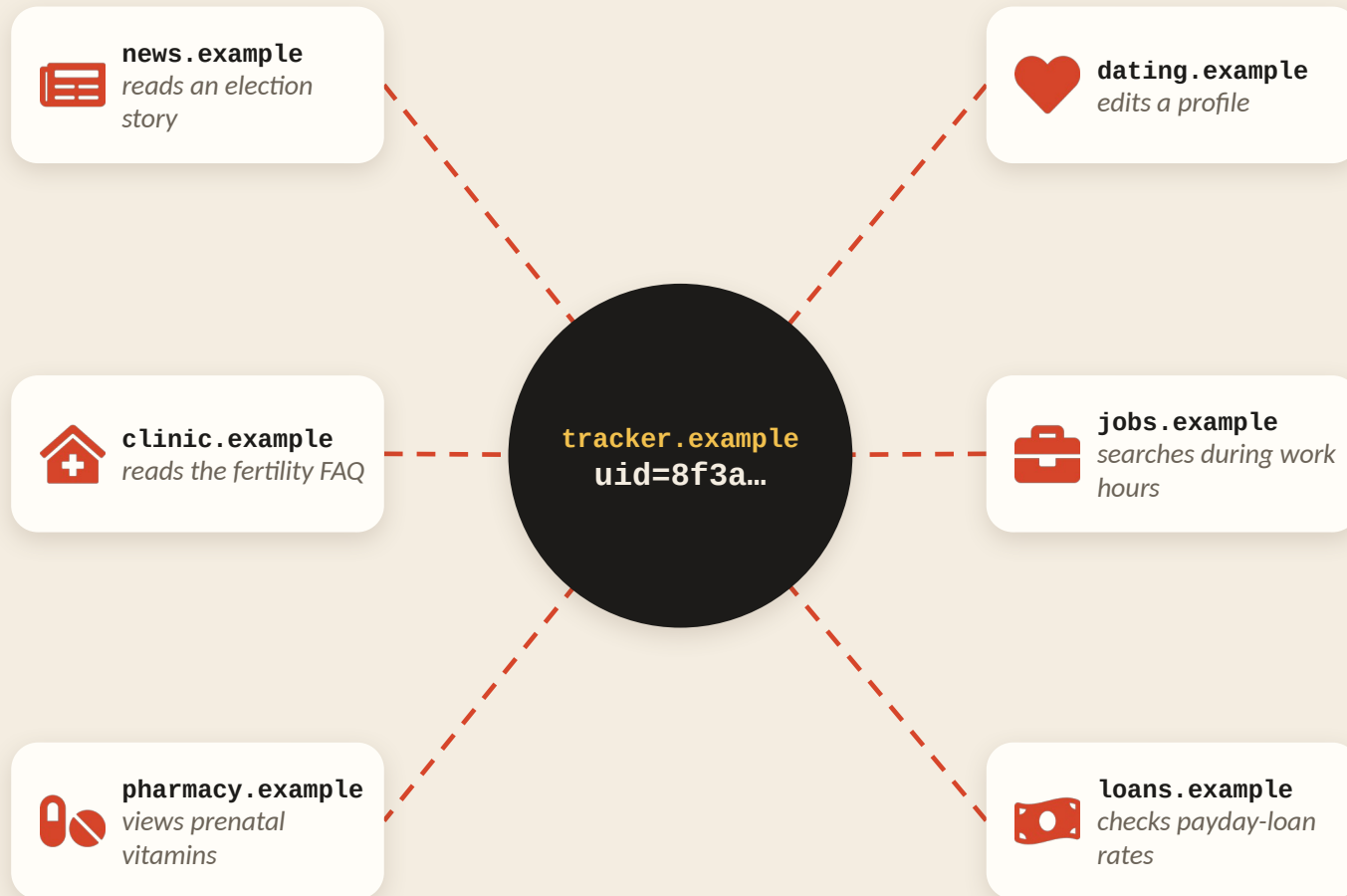
Sent on cross-site requests. Third-party tracking needs exactly this setting.

Partitioned

CHIPS: the embed gets a separate cookie jar for each top-level site — no cross-site join.

Why third-party cookies are the real monster

One tracker embedded on thousands of sites reads the same ID everywhere — a browsing diary nobody agreed to keep.



WHAT THE TRACKER NOW KNOWS

```
uid      8f3a91c2e7
interests politics, fertility,
          prenatal, dating
life_event "likely pregnant"
job_status "quietly looking"
finance    "credit-stressed"
```

INVISIBLE

The user never visited tracker.example and never saw its notice.

PERSISTENT

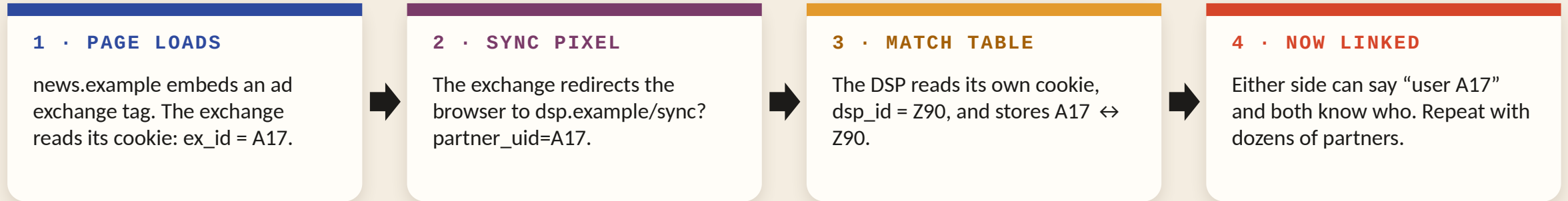
One ID for up to 400 days, on every site that embeds the tag.

RESOLD

The profile feeds ad auctions and data brokers downstream.

Cookie syncing and the bidstream: how your ID spreads

Trackers can't read each other's cookies — so they swap IDs through redirects, then broadcast you in every ad auction.



BID REQUEST → sent to every bidder

```
{
  "site": {"page": "clinic.example/fertility"},
  "device": {"ip": "203.0.113.x", "ua": "...iPhone...",
    "geo": {"lat": 40.71, "lon": -74.00}},
  "user": {"id": "A17", "buyeruid": "Z90"},
  "imp": [{"banner": {"w": 300, "h": 250}}]
}
```

THE PRIVACY PROBLEM

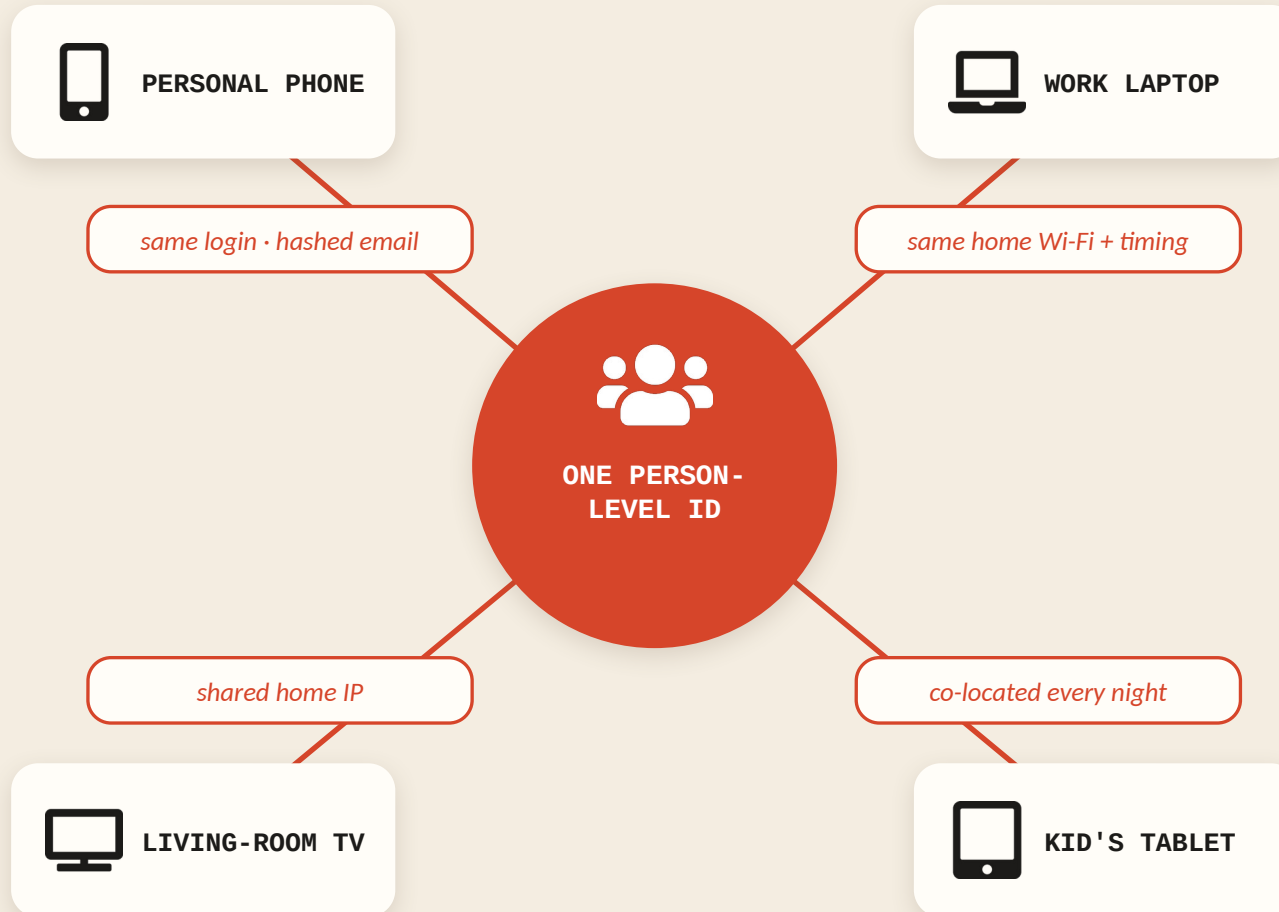
Every bidder receives the request — winners and losers alike. One page view can broadcast the URL, location, and IDs to many companies in milliseconds.

Losing bidders keep what they saw. Nothing technical makes them forget.

Reviewer rule: anything placed in a bid request should be treated as disclosed to third parties.

Cross-device graphs stitch every screen into one person

Clear cookies on one device and nothing resets. The graph re-links you from the others.



DETERMINISTIC

Exact matches: the same login, email, phone number, or loyalty ID seen on two devices.

Precise — requires a sign-in somewhere.

PROBABILISTIC

Statistical guesses from shared IP, Wi-Fi, location patterns, timing, and device traits.

Fuzzier — works with no login, and quietly pulls in the whole household.

IDENTITY GRAPH The table that says “these eleven IDs are one person.” It is the core product data brokers sell.

Why cross-device insight is a threat, not a convenience

Linking devices moves information across contexts people deliberately keep apart.



CONTEXT COLLAPSE

A search on your personal phone shapes the ads on your work laptop — in front of colleagues.



HOUSEHOLD LEAKAGE

A shared IP ties family members together. One person's health or gift searches surface on the family TV.



PERSISTENCE

Delete cookies, reset the ad ID, go private — the graph re-links you from any device it still knows.



INFERENCE TRANSFER

What one device reveals — pregnancy, a job hunt, debt — follows you to every screen you own.



RE-IDENTIFICATION

A logged-out “anonymous” device becomes named the moment it joins a graph that holds an email.

ASK IN EVERY REVIEW

If this signal were joined with everything the company — and its partners — already know, what could they learn?

Fingerprinting: tracking with nothing stored at all

No cookie to clear, no prompt to deny — just enough small facts to make one browser unique.

THE MATH

33 bits

is all it takes to single out one person among 8 billion — because $2^{33} \approx 8.6$ billion.

Every signal adds a few bits. Combine enough of them and the browser is unique — and stays unique after you clear everything.

SIGNAL

IDENTIFYING POWER

Installed fonts



Canvas & WebGL rendering



User agent & platform



Screen size & pixel ratio



Audio processing



Extensions & settings



Time zone & language



CPU cores & memory



●●● high · ●●○ medium · ●○○ low (relative)

HOW PLATFORMS FIGHT BACK

1

Make everyone look alike

Fewer distinct values means fewer bits per signal.

2

Add noise

Safari perturbs canvas, WebGL, and audio readback so the signature is unstable.

3

Block the fingerprinter

Cut off known fingerprinting scripts at the network layer.

4

Ban it by policy

Apple's App Store rules forbid fingerprinting — even when the user allows tracking.

Safari 26: Advanced Fingerprinting Protection on for all browsing

When cookies are blocked, trackers adapt

Block one technique and the industry routes around it. Learn the workarounds so you can spot them in a design doc.

TECHNIQUE	HOW IT WORKS	THE COUNTER
 CNAME cloaking	A tracker hides behind a first-party subdomain (metrics.shop.example → tracker).	Safari caps cookies set this way to 7 days; blocklists uncloak the CNAME.
 Link decoration	Click IDs such as gclid or fbclid ride in the URL to the next site.	Link tracking protection strips known parameters.
 Bounce tracking	A quick redirect through the tracker's domain lets it set a first-party cookie.	Browsers purge storage for redirect-only domains.
 Server-side forwarding	Conversions sent server-to-server through “conversions APIs.”	Invisible to browsers — needs consent checks, contracts, and audits.
 Supercookies	IDs hidden in cache entries, ETags, or HSTS flags reappear after clearing.	Caches and storage partitioned per top-level site.
 Email pixels	A 1×1 image records when, where, and whether you opened a message.	Mail Privacy Protection preloads content through relays.

IDFA: the phone's advertising license plate

One identifier, readable by every app on the device — until Apple put a permission prompt in front of it.



```
import AppTrackingTransparency
import AdSupport

ATTrackingManager.requestTrackingAuthorization { status in
    let idfa = ASIdentifierManager.shared()
        .advertisingIdentifier
    // .authorized → a real, resettable UUID
    // .denied → 00000000-0000-0000-0000-000000000000
}
```

IDFA

Every app on the device · resettable · needs ATT permission

IDFV

One developer's apps only · no prompt · can't be used to track across companies

GAID / AAID

Android equivalent · user can reset or delete · zeros after deletion

WHY IT MATTERED Mobile ad IDs became the join key for location brokers: ad ID + precise GPS = a person's daily path. See the case files, p. 63.

App Tracking Transparency: what counts as tracking

Apple defines tracking by what you link, not what you collect — and the rules apply with or without the IDFA.

DEFINITION

Tracking = linking user or device data from your app with other companies' data for targeted ads or ad measurement — or sharing it with a data broker.

IS TRACKING

- ✗ Targeting ads with data bought from a broker
- ✗ Sending emails or ad IDs to an ad network for retargeting
- ✗ An SDK that merges your app data with other apps' for ads
- ✗ Sharing location or analytics with a data broker

IS NOT TRACKING

- ✓ Linking that happens only on the device and never leaves it identifiably
- ✓ Sharing with a broker solely for fraud detection or security, on your behalf
- ✓ Sharing with a consumer reporting agency for credit purposes

THE RULES AROUND IT

- ▶ No fingerprinting — even if the user taps Allow
- ▶ No rewards or pressure to get an Allow
- ▶ No features locked behind the prompt
- ▶ A denial covers all tracking, not just the IDFA
- ▶ SDKs declare data use in privacy manifests
- ▶ Privacy labels must match real behavior

Measure the ad without identifying the person

Advertisers need to know an ad worked. They don't need to know who you are.

THE OLD WAY

THE PRIVACY-PRESERVING WAY

Web conversions	Third-party cookie ties the click to the purchase	Private Click Measurement: 8-bit campaign ID, 4-bit conversion value, report delayed 24–48 h
App installs	IDFA join inside an attribution vendor	SKAdNetwork / AdAttributionKit: signed postback from the device, delayed, coarse values
Email opens	A tracking pixel per recipient	Mail Privacy Protection: content preloaded via relays, so opens look uniform
Audience analytics	Row-level logs for every user	Aggregates with minimum-count thresholds and differential-privacy noise

FIVE MOVES THAT DO THE WORK

- 1 Aggregate**
Report groups, never rows.
- 2 Delay**
Random delays break the click ↔ buy join.
- 3 Coarsen**
A few bits of value, not the full event.
- 4 Threshold**
Nothing reported below a crowd size.
- 5 Add noise**
Differential privacy bounds any one person.

Same toolbox as pp. 32–37.

Where the defenses stand in 2026

Defaults decide outcomes — most people never change a setting.

PLATFORM	THIRD-PARTY COOKIES / IDs	FINGERPRINTING	LINK & REDIRECT TRACKING
Safari	Blocked by default since 2020; script-set cookies capped at 7 days	Advanced Fingerprinting Protection for all browsing (Safari 26)	Known click IDs stripped; bounce mitigations
Firefox	Total Cookie Protection partitions every cookie (default since 2022)	Known fingerprinters blocked	Redirect-tracker cleanup; query stripping in Strict mode
Brave	Third-party cookies blocked	Fingerprint values randomized per site	Known tracking parameters stripped
Chrome	Still on by default — phase-out abandoned; blocked in Incognito	Limited protections by default	Limited by default
iOS apps	IDFA and all cross-company tracking gated by ATT	Banned by App Store policy	Stripped in Mail, Messages, private browsing
Android apps	Advertising ID available unless the user deletes it	Restricted by Play policy	Depends on the app and browser

strong by default

partial

weak by default

Google retired most Privacy Sandbox APIs (Topics, Protected Audience, Attribution Reporting...) in Oct 2025.

Tracking case files: when pixels meet sensitive data

Every one of these started as an ordinary marketing or analytics integration.

GoodRx

FTC · 2023

Shared prescription and health details with ad platforms through pixels and SDKs, despite privacy promises. First Health Breach Notification Rule case: \$1.5M penalty and a ban on sharing health data for ads.

LESSON *A “standard” pixel on a health page is a health-data disclosure.*

BetterHelp

FTC · 2023

Online counseling service shared emails, IP addresses, and intake answers with advertisers after promising privacy. \$7.8M for refunds; barred from sharing health data for advertising.

LESSON *Hashed emails of therapy seekers are still health data.*

Hospital pixels

2022 →

Reporting found ad pixels on many hospital websites and patient portals, sending appointment details. HHS issued tracking-technology guidance; a court later narrowed part of it (2024).

LESSON *Tracking code on a logged-in page sees what the patient sees.*

Kochava

FTC · 2022 →

Location broker sold precise coordinates tied to mobile ad IDs, exposing visits to clinics, places of worship, and shelters. A proposed settlement bars selling sensitive location data without express consent.

LESSON *An “anonymous” ad ID plus precise location is a person.*

Pattern: the pixel or SDK behaved exactly as designed. What failed was a review that never asked where the events went.

“Marketing wants to send hashed emails to an ad platform”

A real, common request. Walk it with the 8 questions (p. 43) and land on a better design.

THE ASK

“Upload SHA-256 hashes of customer emails with purchase events so the ad platform can match them and optimize our campaigns.”

WEAK ANSWER

~~“It’s hashed, so it’s anonymized.”~~

The platform can hash its own users’ emails and match yours exactly. That match is the whole point of the product.

STRONG ANSWER

1

Name it

A hashed email is a stable identifier — pseudonymous, never anonymous.

2

Classify it

Linking with another company’s data for ads is tracking under ATT and “sharing” under CPRA.

3

Minimize

Only consented users; never health, finance, or kids’ contexts; no raw event detail.

4

Prefer aggregate

Clean room with thresholds, or on-device attribution instead of person-level uploads.

5

Enforce

Consent and GPC checked at send time, partner retention limits, audit logs.

RED FLAGS IN ANY TRACKING DESIGN

- 🚩 An SDK added without an egress review
- 🚩 Device signals collected “for fraud,” then shared with ad partners
- 🚩 Full URLs with query strings sent to third parties
- 🚩 Pixels on logged-in or sensitive pages
- 🚩 ID lifetimes longer than the purpose
- 🚩 No path for an opt-out to reach partners

See it in practice: how Apple builds privacy.

Principles become architecture. Architecture becomes products people use every day — then you practice the judgment yourself.

IN THIS LEVEL

APPLE PRINCIPLES

APPLE ARCHITECTURE

SPEAK APPLE

THE CORE

DESIGN EXERCISE

RISK MEMO

PUSHBACK

SELF-TEST

LANGUAGE

TEAM QUESTIONS

STUDY PATH

0

1

2

3

Four principles Apple repeats everywhere

Learn them as design rules you can apply on a whiteboard, not as slogans.

1

DATA MINIMIZATION

Collect only what is needed.

SHOWS UP AS

Maps uses random, rotating identifiers rather than your Apple Account.

2

ON-DEVICE PROCESSING

Keep computation local when possible.

SHOWS UP AS

Photos recognizes people and scenes on the device itself.

3

TRANSPARENCY & CONTROL

Make every use understandable and controllable.

SHOWS UP AS

App Tracking Transparency, privacy nutrition labels, App Privacy Report.

4

SECURITY

Protect data across its whole lifecycle.

SHOWS UP AS

Secure Enclave, end-to-end encryption, Advanced Data Protection.

The strongest control is the field you never collect

Same feature, two payloads. Read them the way a reviewer would.

SERVER-FIRST PAYLOAD

```
{
  "user_id": "a91f-22c0-...",
  "device_id": "E3C1-7F0A-...",
  "url": "https://clinic.example/...?q=...",
  "ts": "2026-09-25T14:03:17.412Z",
  "history_days": 90
}
```

✗ joins to a person ✗ reveals a clinic visit ✗ kept for 90 days

MINIMUM USEFUL SIGNAL

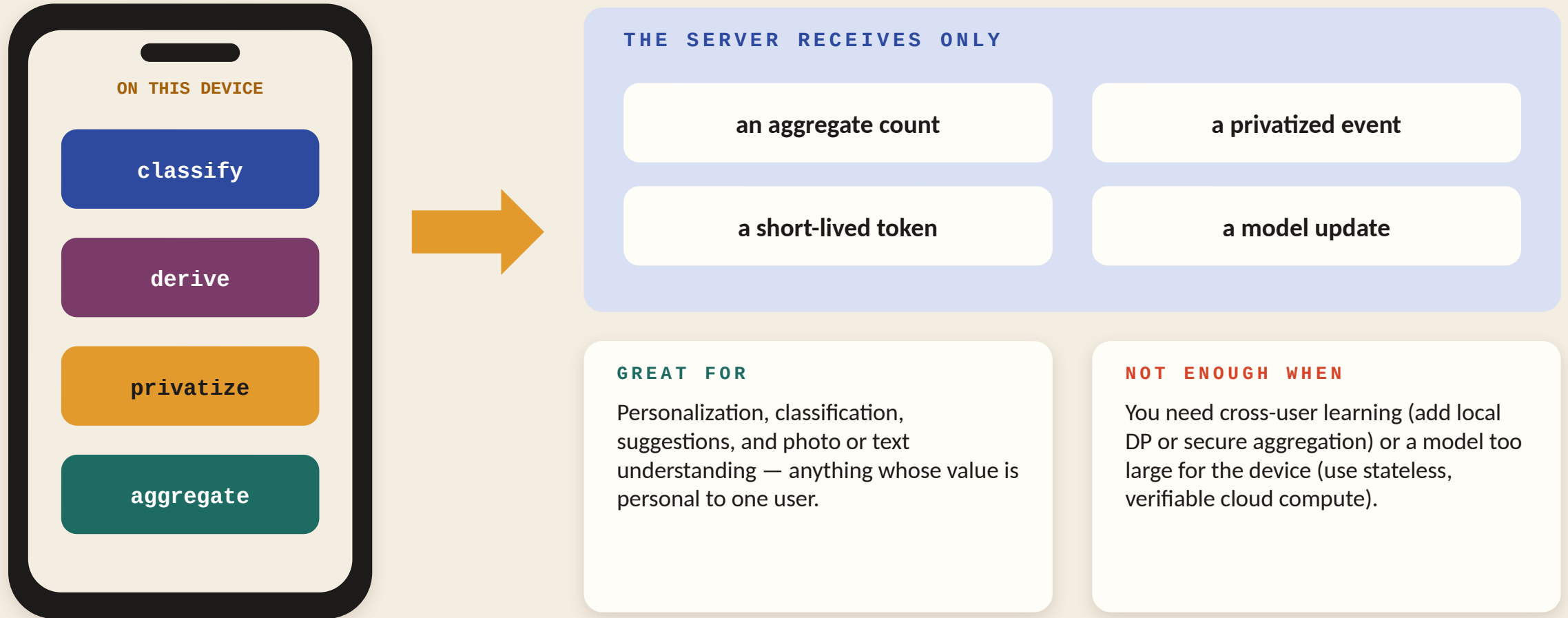
```
{
  "category": "health",
  "time_bucket": "afternoon",
  "report": "<privatized on device>",
  "ttl": "7d"
}
```

✓ no person key ✓ coarse time ✓ one-week TTL

Reviewer's line: "Separate what is required from what is merely convenient."

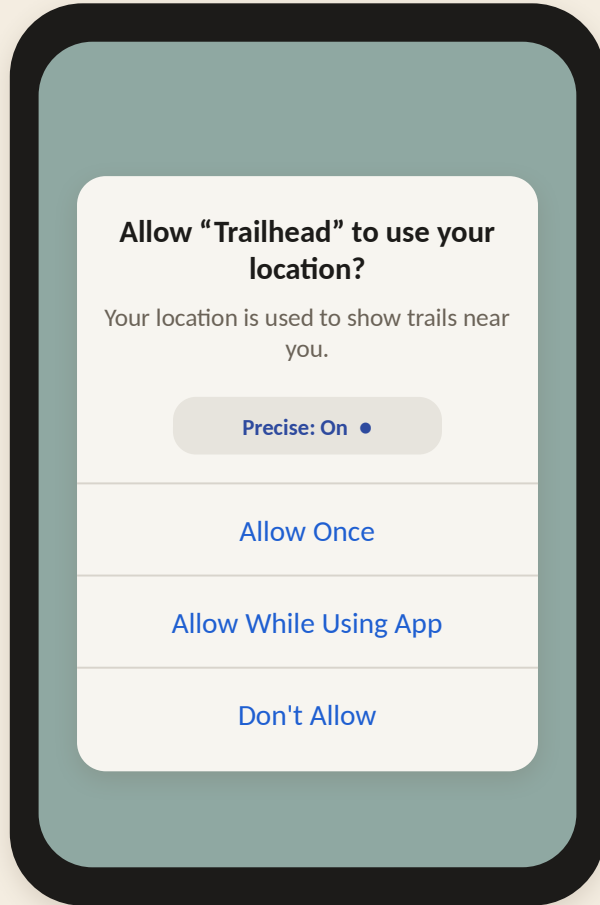
Move intelligence toward the user

When the server does not need raw data, do the work where the data already lives.



Informed control, in the moment

Users should understand the important choice before it becomes irreversible.



1

BEFORE

Explain what will happen — in the moment, in plain words.

Apple: Purpose strings inside permission prompts

2

CHOICE

Offer real, granular options — not all-or-nothing.

Apple: Approximate vs. precise location; limited photo access

3

AFTER

Let people review and change it later.

Apple: Settings › Privacy & Security; App Privacy Report

A buried toggle is not the same as informed control.

Study the architecture, not the slogans

Apple's public materials show privacy decisions embodied in system design. Know what each one reduces.



Safari

Intelligent Tracking Prevention · storage partitioning · fingerprinting defenses

REDUCES LINKABILITY



Apple Pay

Device Account Number instead of your card number · Secure Element · one-time dynamic codes

REDUCES IDENTITY



Differential privacy

Device-side privatization · no device identifiers on reports · aggregate-only learning

REDUCES DATA



Private Cloud Compute

Stateless cloud AI · no privileged runtime access · verifiable software images

REDUCES TRUST



iCloud Private Relay

Two separate relays, so no single party sees both who you are and where you go

REDUCES LINKABILITY



Mail Privacy Protection

Loads remote content privately — hides your IP and open activity from senders

REDUCES DATA

Design lesson: say which of trust, data, identity, or privileged access your design reduces.

Speak Apple: every product, one privacy song.

Devices, iCloud, Keychain, Wallet, partners, and AI — explained in the words Apple engineers actually use.

IN THIS MODULE

THE CHORUS

PHRASEBOOK

SILICON

iCLOUD + ADP

KEYCHAIN + PASSKEYS

MESSAGES + FIND MY

HANDSHAKE RULE

PAY + CARD

IDENTITY

APPLE INTELLIGENCE

EVERYDAY APPS

CONTROLS

HARD PARTS

DRILL

0

1

2

3

The four-beat sentence that sounds like Apple

Say the beats in order. It works for a chip, an app, a cloud service, or a partner deal.

THE CHORUS

	BEAT 1 What it does for you	BEAT 2 Where it happens	BEAT 3 Who can see it	BEAT 4 What you control
Face ID	Unlock with a glance	Secure Enclave, on the device	Never leaves the iPhone; not in iCloud	Passcode anytime; choose per app
Apple Pay	Pay with a tap	A device-only number in the Secure Element	The merchant never gets your card number	Pick the card; remove it remotely
Photos	Finds people, places, memories	Analyzed on your iPhone	Apple doesn't see your library	Limited access per app; hide people
Siri	Gets things done	On device first, then Private Cloud Compute	A random identifier — not your Apple Account	Delete history; audio review is opt-in

Sing all four beats and it sounds like Apple. Skip beat 3 and it sounds like everyone else.

Say it the Apple way

Same idea, different music. The right words prove you understand the architecture behind them.

SOUNDS LIKE EVERYONE

"We collect data to personalize the experience."

"The data is encrypted."

"It's anonymized."

"We share it with partners."

"Users can opt out in Settings."

"We keep logs to improve the model."

"It runs in our cloud."

"Privacy is a compliance requirement."



♪ SOUNDS LIKE APPLE

It's processed on device — personal, and private.

End-to-end encrypted: only your trusted devices hold the keys. Not even Apple can read it.

Not linked to your Apple Account — a random identifier that rotates.

The partner gets a token, not your identity.

You're in control — the choice appears in context, at the moment it matters.

Stateless: processed, answered, gone. Helping improve it is opt-in.

Private Cloud Compute: Apple silicon, verifiable by independent researchers.

Privacy is a fundamental human right — designed in from the first sketch.

It starts in the silicon

Before any policy runs, the hardware decides who can read what.



Secure Enclave

A separate processor that guards the keys — Face ID math, Apple Pay numbers, passcode checks. The main OS never sees them.

♪ *Isolated from the main processor, by design.*



Face ID & Touch ID

Biometric data is stored in the Secure Enclave — never uploaded, never in a backup. Apps learn only “matched” or “not matched.”

♪ *Your face never leaves your iPhone.*



Data Protection

Every file gets its own key, wrapped by keys tied to your passcode. Lock the phone and protected files are unreadable.

♪ *Encrypted by default — no setting required.*



Stolen Device Protection

Away from familiar places, sensitive changes need Face ID plus a security delay. A stolen passcode is no longer enough.

♪ *A thief with your passcode still can't take over.*



Lockdown Mode

Optional, extreme protection for people targeted by mercenary spyware: fewer features, a far smaller attack surface.

♪ *Protection sized to the threat.*



Activation Lock

A lost or stolen iPhone stays tied to its owner's Apple Account — worthless to anyone else.

♪ *Your device is only ever yours.*

iCloud: whoever holds the key decides who can read it

Both tiers encrypt everything. The difference is key custody — and who can help you recover.

STANDARD DATA PROTECTION · THE DEFAULT

Encrypted in transit and at rest. For most categories Apple keeps the keys in hardware security modules — so Apple can help you recover, and can answer lawful requests.

ALWAYS END-TO-END, EVEN HERE

Passwords & Keychain

Health

Journal

Home

Messages in iCloud*

Payment info

Screen Time

Safari

Wi-Fi passwords

Maps

Siri info

ADVANCED DATA PROTECTION · OPT-IN

End-to-end encryption for 25 categories. Only your trusted devices hold the keys — Apple cannot read the data, even if asked.

ADDS THESE TEN

iCloud Backup

iCloud Drive

Photos

Notes

Reminders

Safari Bookmarks

Siri Shortcuts

Voice Memos

Wallet Passes

Freeform

STAYS STANDARD

Mail, Contacts, and Calendars — they must work with the world's email and calendar systems.

THE TRADE-OFF

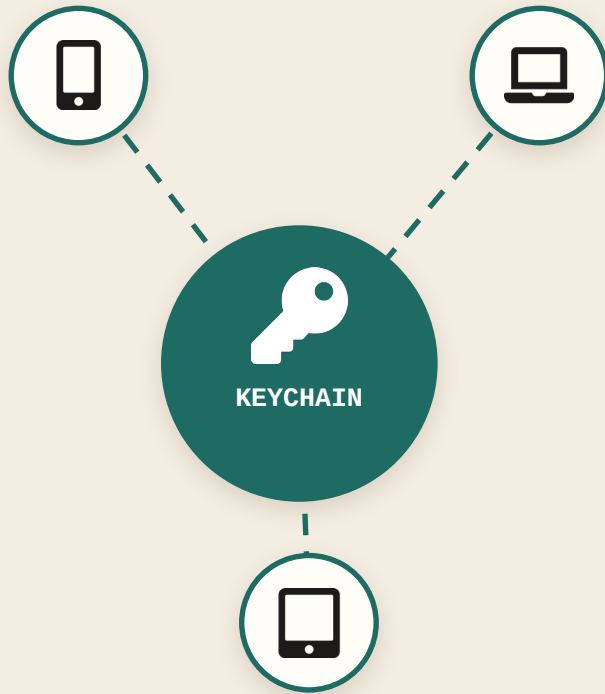
You own recovery: a recovery contact or a recovery key. Apple can't reset it for you.

THE UK LESSON

Facing a 2025 government order, Apple withdrew ADP for new UK users rather than build a backdoor; the legal fight continued into 2026.

Keychain & passkeys: secrets that sync without being seen

Your passwords follow you to every device — and Apple never holds a readable copy.



HOW A PASSKEY WORKS

1

Sign up

Your iPhone makes a key pair. The website stores only the public key.

2

Sign in

The website sends a one-time challenge.

3

Face ID

Unlocks the private key, which signs the challenge on your device.

4

Breach-proof

A leaked public key is useless, and the passkey only works on the real website.

Password Monitoring

Checks your passwords against known leaks without revealing them to Apple.

Shared groups

Share a set of passwords with family — end-to-end encrypted.

Verification codes

Two-factor codes built in, filled automatically.

END-TO-END SYNC ACROSS YOUR TRUSTED DEVICES

A new device joins only with an existing device or your passcode. Recovery escrow lives in hardware security modules that destroy it after 10 wrong guesses.

🎵 *Your passwords are end-to-end encrypted. Apple can't see them — and passkeys can't be phished.*

Messages, FaceTime & Find My: private by architecture

Talk, share where you are, find what you lost — with Apple unable to read or locate any of it.



End-to-end by default

iMessage and FaceTime content is readable only on the devices in the conversation.



Post-quantum (PQ3)

iMessage protects against “harvest now, decrypt later” attacks by future quantum computers.



Contact Key Verification

Confirm you're talking to exactly who you think — alerts if a new device appears.



Communication Safety

Detects nudity on device for children and offers help. Apple isn't notified.

🎵 *Only the people in the conversation can read it.*

FIND MY · HOW A LOST AIRTAG GETS FOUND

1

Broadcast

The lost item sends a rotating public key over Bluetooth — no stable ID.

2

Encrypt

A passing Apple device encrypts its own location with that key and uploads it.

3

Store blind

Apple's servers hold a sealed blob: no location, no finder identity.

4

Decrypt

Only the owner's devices hold the private key to open it.

THE FLIP SIDE Trackers can be misused for stalking, so iPhone and Android now alert you when an unknown tracker travels with you.

The handshake rule: share a token, never the person

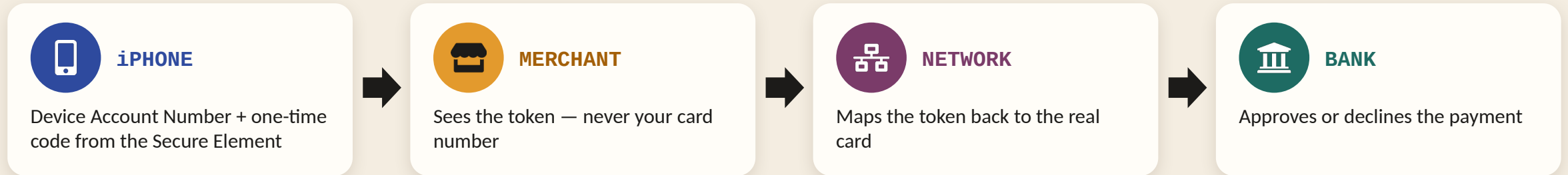
A token, a relay, a proof, a permission, or an aggregate. Name the pattern and you've explained the design.



Design move: for any partner integration, name the pattern first — then the data, the retention, and the contract.

Apple Pay & Apple Card: the money handshake

A payment needs a bank, a network, and a merchant. Apple designs it so none of them gets more than its part.



♪ *Apple doesn't keep transaction details that can be tied back to you. Recent purchases live in Wallet, on your device.*

APPLE CARD · THE PROMISE

Apple doesn't know what you bought, where, or how much.

The issuing bank runs the account and has committed not to share or sell your data for marketing or ads.

Spending insights are computed on your iPhone, in Wallet.

A virtual card number you can change keeps online shopping apart from the physical card.

LIVE CASE · THE ISSUER SWITCH

Jan 2026: Apple and Chase announced Chase will replace Goldman Sachs as issuer over about 24 months. What does a privacy reviewer ask?

- 1 Which data moves — only what servicing the account needs?
- 2 Do the same “no marketing, no ads” limits bind the new bank?
- 3 How are customers told, and what choices do they get?
- 4 When does the old issuer delete — and how is it verified?

Sign in, show ID, share health: the identity handshakes

The user proves who they are — or shares one fact — without handing over a profile.



Sign in with Apple

- The app gets a name you can edit and an email — your real one or a Hide My Email relay.
- Apple doesn't track what you do in the app.
- Two-factor authentication comes built in.

🎵 *A private sign-in the app can't use to follow you.*



Wallet ID & Digital ID

- Driver's licenses, and since Nov 2025, an ID built from a U.S. passport — accepted at TSA checkpoints.
- You see exactly which fields are requested and approve with Face ID; only those are shared.
- No need to unlock or hand over your iPhone.

🎵 *Share the fact, not the whole card.*



HealthKit

- Permission per data type: steps yes, heart rate no.
- A denied read looks exactly like "no data," so an app can't infer what you chose to hide.
- Health data is end-to-end encrypted in iCloud.

🎵 *You decide which app sees which data.*

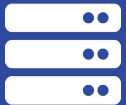
Apple Intelligence: three tiers, one boundary

On device when it can, Private Cloud Compute when it must, an outside model only when you say yes.



TIER 1 · ON DEVICE

Most requests. Your personal context — mail, messages, photos — is read locally, and never leaves.



TIER 2 · PRIVATE CLOUD COMPUTE

Bigger models on Apple silicon servers. Stateless, no privileged access for staff, software published for researchers — your iPhone refuses servers it can't verify.



TIER 3 · OUTSIDE MODEL · CHATGPT

Siri asks before sending anything. Your IP address is hidden, and OpenAI doesn't store the request unless you sign in.

♪ *Siri requests use a random identifier, not your Apple Account. Audio is reviewed only if you opt in.*

2026 · GEMINI INSIDE

Apple and Google announced that the next Apple Foundation Models are based on Gemini. Apple says Apple Intelligence still runs on device and in Private Cloud Compute.

The model can come from a partner. The data stays inside Apple's boundary.

ASK OF ANY AI PARTNERSHIP

- ▶ Where does it run, on whose hardware?
- ▶ Can outside researchers verify it?
- ▶ Does any prompt or output reach the partner?
- ▶ What is kept, and for how long?

Maps, Photos, Home, Health: the same song in every app

Different products, same four beats. Learn one example per app and you can improvise the rest.



Maps

No sign-in needed. Requests use random identifiers that rotate; Look Around blurs faces and license plates.

♪ *Maps doesn't know who you are.*



Photos

People and scenes are recognized on device. Landmark lookup uses homomorphic encryption, noise, and a relay.

♪ *Apple never sees your photos.*



Home

HomeKit Secure Video analyzes camera footage on your home hub; clips are end-to-end encrypted in iCloud.

♪ *Your home stays yours.*



Health

Encrypted on the device with your passcode, end-to-end in iCloud, shared only per app and per type.

♪ *Your health data, under your control.*



Mail

Mail Privacy Protection hides your IP address and whether you opened a message.

♪ *Senders can't watch you read.*



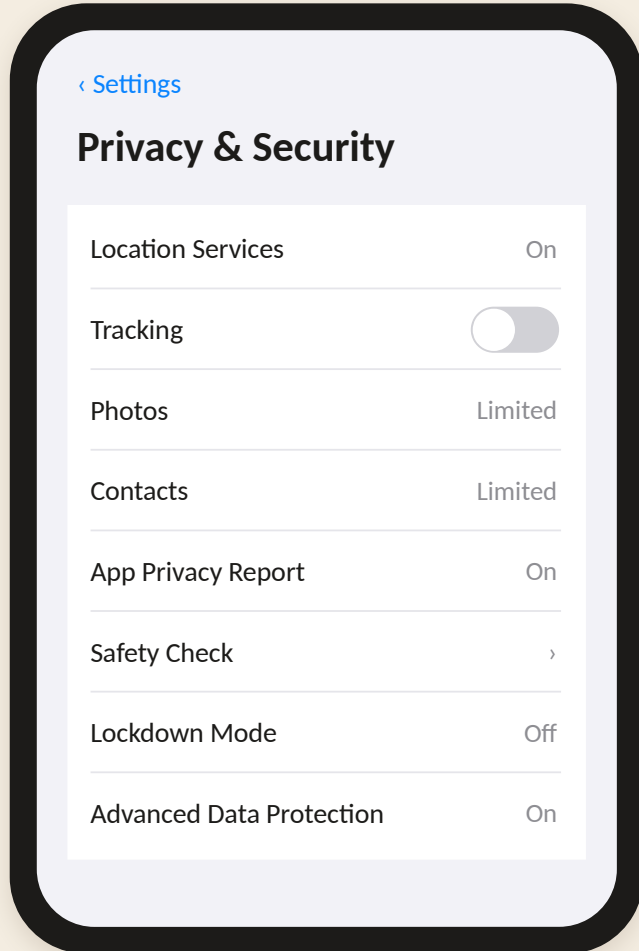
Keyboard

Your typing patterns and new words are learned on device; the vocabulary syncs end-to-end.

♪ *It learns you, privately.*

Every promise has a switch

Transparency and control means the user can see it and change it — in Settings, or in the moment.



App Privacy Report

See which apps touched your camera, location, and contacts — and which domains they contacted.

Safety Check

One place to review and reset who can see your data — built for people leaving abusive relationships.

Precise Location off

Apps get an approximate area instead of your exact spot.

Limited access

Share only the photos or contacts you pick, not the whole library.

Ask App Not to Track

The ATT prompt (p. 60) — a denial covers all cross-company tracking.

Advanced Data Protection

Turn it on and you hold the keys to 25 iCloud categories (p. 75).

Where the privacy story was tested

Experts don’t just recite the promise. They know where it bent — and how Apple answered.

TENSION	WHAT HAPPENED	WHAT TO SAY
Encryption vs. government	A 2025 UK order sought access; Apple withdrew ADP for new UK users rather than build a backdoor, and fought on in 2026.	<i>Refusing the key can cost a market. That is what end-to-end means.</i>
Child safety vs. scanning	A 2021 plan to match photos on device was paused after pushback, then dropped in Dec 2022.	<i>Apple chose on-device nudges for kids over scanning everyone’s library.</i>
Human review of Siri	Reports in 2019 that contractors heard recordings; Apple paused grading, apologized, and made it opt-in.	<i>Default off, opt-in, first-party only.</i>
Default-on features	Enhanced Visual Search (2024) was on by default; critics wanted opt-in despite strong cryptography.	<i>Strong math doesn’t replace informed choice.</i>
Local law	In mainland China, iCloud is operated by a local partner under national rules.	<i>Name the constraint honestly; show which protections still hold.</i>
Partner models	Next-gen Apple Foundation Models are built on Gemini (2026).	<i>The model’s supplier is not the data’s recipient — prove it with verifiability.</i>

Make it sound like music: the out-loud drill

Pick a feature. Sing the four beats. Name the handshake. Say it in under 30 seconds.

▶ EIGHT LINES TO HAVE READY

- 1 The best way to protect data is not to collect it.
- 2 It's processed on device, so it stays with you.
- 3 End-to-end encrypted — not even Apple can read it.
- 4 Not linked to your Apple Account.
- 5 The partner gets a token, not the person.
- 6 Stateless: nothing is kept after the answer.
- 7 Verifiable — researchers can inspect what runs.
- 8 You're in control, in context, in the moment.

WORKED EXAMPLE · JOURNAL SUGGESTIONS

BEAT 1

Suggests moments worth writing about

BEAT 2

Built on device from photos, workouts, and places

BEAT 3

Entries end-to-end encrypted in iCloud

BEAT 4

Pick the sources; lock Journal with Face ID

HANDSHAKE: PERMISSION — per source

YOUR TURN — FILL THE FOUR BEATS OUT LOUD

Tap to Pay on iPhone

1

2

3

4

Live Voicemail transcripts

1

2

3

4

Sharing your location with family

1

2

3

4

Peel the onion.

Features are the skin. Architecture is the flesh. At the core: who makes money from knowing you — and who can force you to hand it over.

IN THIS MODULE

- THE BURN BUTTON
- THE ONION
- FOLLOW THE MONEY
- WHY IDFA EXISTS
- WHY ATT
- MAPS vs MAPS
- THE SUBPOENA TEST
- THE HISTORY HOLE
- HOW BREACHES SPREAD
- STOP THE SPREAD
- APPLE vs META
- DECODING THE FEUD
- AI BREAKS 8 RULES
- AI INCIDENTS
- WHERE AI THINKS
- FORGET ME



One button: what Steve Jobs would do with a cookie banner

Complexity is where consent goes to die.

THE STORY, AS IT'S TOLD

A team showed Steve Jobs a many-step design for burning a DVD. He went to the whiteboard, drew one window with one button, and wrote:

Burn.

The product absorbs the complexity. It never hands it to the person.

THE DVD-BURNER DECK

We value your privacy

We and our 847 partners store and access information on your device and process personal data based on consent and legitimate interest for...

- Strictly necessary ☒
- Measure content performance ☐
- Personalised ads & profiles ☐
- Precise geolocation data ☐
- Legitimate interest (object ▼) ☐

ACCEPT ALL

Manage 847 partners · reject

THE BURN BUTTON

Allow “Shop” to track your activity across other companies’ apps and websites?

Your data will be used to deliver personalized ads to you.

Ask App Not to Track

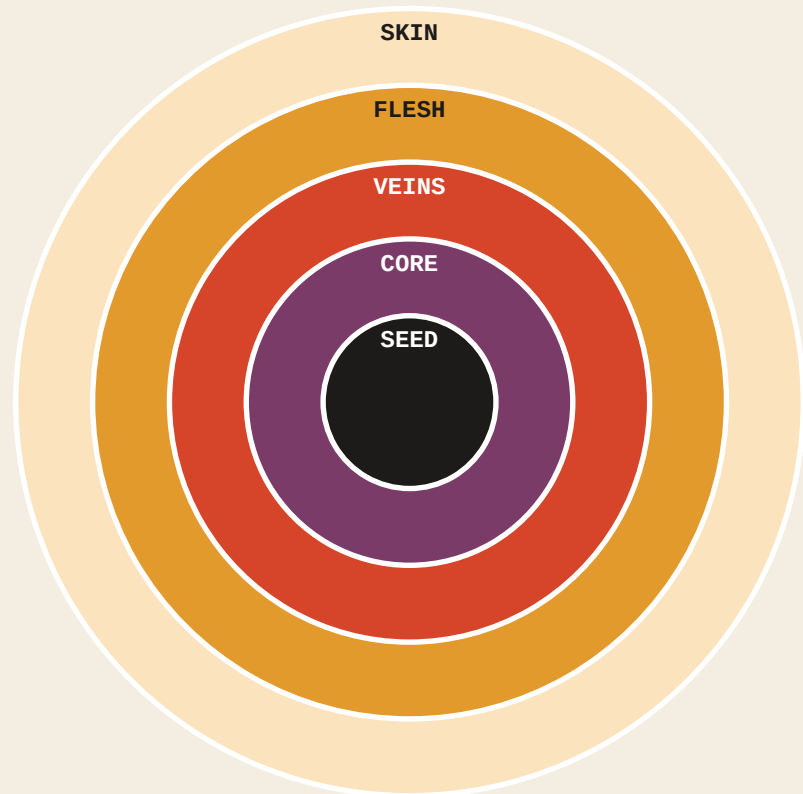
Allow

• THE BUTTON

The best privacy setting is the default nobody has to find. One honest question beats 847 toggles.

Five layers under every privacy feature

Most debates happen at the skin. Most decisions are made at the core.



SKIN The feature

What does the user see and tap?

A toggle, a prompt, a privacy label

FLESH The architecture

Where does the data live? Who holds the key?

On device, end-to-end, or readable on a server

VEINS The data flows

Who else receives it — and what can they join it with?

SDKs, partners, brokers, bid requests

CORE The business model

Who makes money from knowing you?

Devices, subscriptions — or advertising

SEED Power

Who controls the platform — and who can force access?

App store rules, regulators, courts, governments

• THE BUTTON

To predict a company's privacy, don't read its settings. Read its income statement.

Follow the money: why the three giants behave differently

Privacy architecture follows revenue. Here is where the revenue comes from.

Meta



Sells attention. Needs to know you across the web and apps.

Alphabet



Sells attention too — but also a phone OS, a browser, and a cloud.

Apple



Sells hardware and services. Knowing you less costs it little.

THE TWISTS NOBODY PUTS ON A SLIDE

~\$20B a year

Google paid Apple to be Safari’s default search engine (2022, per trial testimony). Apple profits from Google’s ads.

Apple sells ads too

App Store search ads run on Apple’s own first-party data — which its rules don’t count as “tracking.”

Google copies Apple

On-device Timeline (2024) and Private AI Compute (2025) mirror Apple’s architecture.

• THE BUTTON

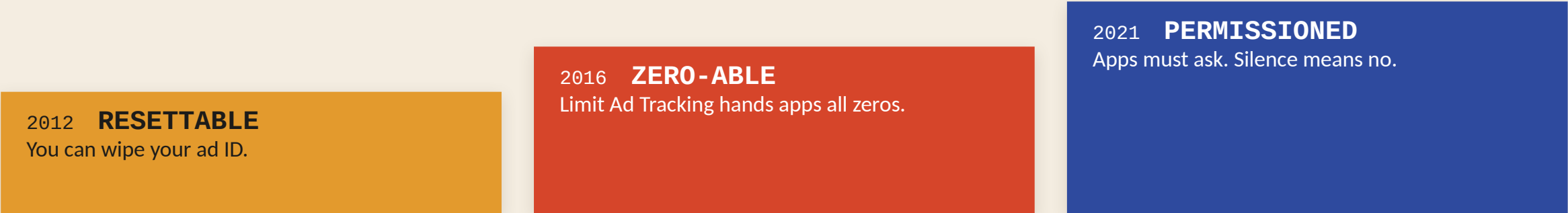
A company can afford not to know you exactly as much as its revenue doesn’t depend on knowing you.

Why Apple invented the IDFA — and then fenced it in

Apple didn't end tracking in 2012. It gave tracking an off-ramp, then moved the default one notch at a time.



THEN THE DEFAULT MOVED, ONE NOTCH AT A TIME



• THE BUTTON *Don't fight a whole industry at once. Move the default one notch — then another — until the default is “no.”*

Why ATT was exactly what Apple wanted

Four motives, all true at once — and the regulators who pushed back.



BRAND

Privacy became a reason to pay more for an iPhone — “Privacy. That’s iPhone.”



ASYMMETRY

The rule costs Apple little and ad-funded rivals a lot. Meta put its 2022 hit at about \$10 billion.



RULE-MAKER

Apple defines “tracking,” writes the prompt, and runs the only store on the phone.



FIRST-PARTY EDGE

Apple’s own ads use App Store data — which its definition doesn’t count as tracking.

WHAT USERS GOT

One honest, identical question in every app — and a “no” that apps must respect. When asked plainly, most people say no.

WHAT REGULATORS SAID

France fined Apple €150M (2025) and Italy €98.6M (2025) — not for protecting privacy, but for how: third-party apps needed two consent prompts while Apple’s own apps didn’t.

• THE BUTTON

Both are true: ATT protected users and advantaged Apple. Good privacy can also be good strategy.

Apple Maps vs Google Maps: same trip, two philosophies

Myth check first: Google moved Timeline onto your phone in 2024–25. The real gap is identity and incentive.

	APPLE MAPS	GOOGLE MAPS
Who you are	No sign-in needed. Requests use random identifiers that rotate.	Built around your Google Account when you're signed in.
Where you've been	Significant Locations stay on your device, end-to-end encrypted in sync.	Timeline now lives on your device, with an optional end-to-end encrypted backup.
What you searched	Not tied to an account; precise location fuzzed over time.	Saved to Web & App Activity if that setting is on — with auto-delete options.
Who pays for it	Device and services revenue.	Advertising across Search, YouTube, and Maps.
The court test	Little server-side history to hand over.	Answered geofence warrants for years — until Timeline moved on-device (2025).

• THE BUTTON

The difference isn't the map. It's whether the map knows it's you — and who profits if it does.

Data you keep is data you can be forced to give

Every copy on a server is a copy a court, a government, or an attacker can demand.

THE GEOFENCE WARRANT

“Give us every phone that was near this spot, at this time.”

No suspect needed — just a company that kept everyone’s location. Innocent people inside the circle became leads.

It only works if someone kept the data.

Years of requests

Google says it objected to more than 3,000 geofence warrants on constitutional grounds.

Dec 2023

Google announces Location History will be stored on the device.

July 2025

All server-side Location History is deleted or migrated. Google can no longer answer geofence warrants.

June 2026

Supreme Court, 6–3 (Chatrie): location history held by a company is protected — police access is a Fourth Amendment search.

The Apple parallel

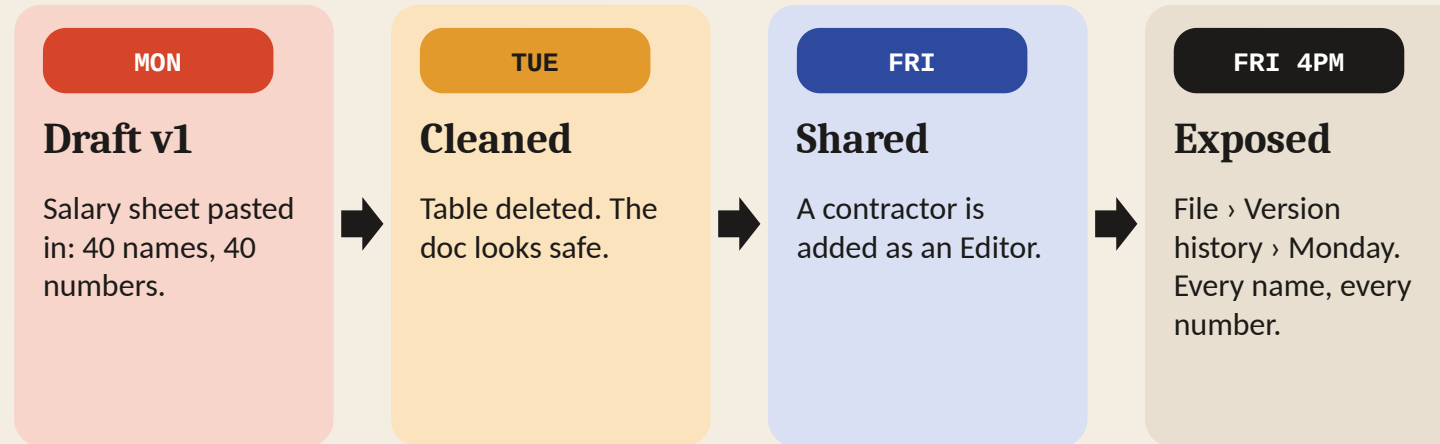
Faced with a UK order, Apple pulled Advanced Data Protection for new UK users rather than build a key it could be forced to use.

• THE BUTTON

The only data that can’t be subpoenaed, breached, or sold is data you never kept.

Deleted isn't gone: the Google Docs version-history hole

You removed the secret on Tuesday. On Friday you shared the doc as an editor. They can read Monday.



WHO CAN OPEN THE PAST



The cruel part: an editor added today sees every version from before they joined — and a link set to “anyone can edit” hands the history to strangers.

THE CLEAN-ROOM FIX

- !** You can't delete one old version
Native Docs keep their history; there is no per-version delete.
- 1** Make a copy
File > Make a copy. History doesn't travel — leave comments unticked.
- 2** Share the copy, not the original
Viewers and commenters never see history at all.
- 3** Retire the original
Trash holds it 30 days; your org's retention rules may hold it longer.

• THE BUTTON

Permission to edit the present is permission to read the past.

Eight places “deleted” data keeps living

Docs are the loudest example, not the only one. Every tool that remembers edits is a leak waiting for the wrong reader.



VERSION HISTORY

Google Docs

Docs, Sheets, Slides, Notion, Confluence: every editor can rewind.



HIDDEN METADATA

Word metadata

A 2003 UK government dossier's Word file named the officials who had edited it.



FAKE REDACTION

PDF redaction

A 2019 court filing for Paul Manafort used black boxes over text you could still copy.



CODE HISTORY

Git

A password committed and then deleted lives on in every clone and fork. Rotate it.



SENT MESSAGES

Email & chat

Edits, recalls, and unsends rarely reach copies already in inboxes, exports, and backups.



TRASH & BACKUPS

Drives & servers

Recycle bins, snapshots, and legal holds keep “deleted” files for weeks or years.



INDEXES & CACHES

Search & previews

Search indexes, previews, and thumbnails keep their own copy of what you removed.



AI MEMORY

Assistants & models

An assistant's memory, logs, or training set may hold what the source no longer does.

• THE BUTTON

Delete removes it from your view. History keeps it for everyone else.

Build history that knows who it's for

Version history is a feature and a leak. Six design rules for engineers — and a one-minute check for everyone else.

1

Separate the permissions

Seeing today's document shouldn't automatically mean seeing every past version.

2

Purge across time

A redaction must reach old versions, backups, and indexes — with an audit trail.

3

Share snapshots, not live files

Send a flattened copy to outsiders; keep the working draft inside.

4

Give history a retention clock

Old versions are data too: expire them like logs.

5

Scan the past on share

Before a new person gets access, check old versions for secrets and personal data.

6

Treat exposure as permanent

A leaked key or password is burned. Rotate it — deleting isn't enough.

BEFORE YOU HIT SHARE

- ☐ Does this person need Editor, or just Viewer?
- ☐ Is the link set to "anyone"?
- ☐ Was anything sensitive ever in this file?
- ☐ Are resolved comments hiding secrets?
- ☐ Would a clean copy be safer?

• THE BUTTON

If it was ever in the document, assume it's still in the document.

How a breach spreads: four real multipliers

Attackers rarely steal everything directly. They find a door, then ride the connections.



THE FEATURE THAT LINKS PEOPLE

23andMe · 2023

~14,000

accounts entered with reused passwords



~6.9 million

people exposed through the “DNA Relatives” feature



THE SHARED VENDOR

MOVEit · 2023

1 flaw

in one file-transfer tool



thousands

of organizations — tens of millions of people



THE MISSING SECOND FACTOR

Snowflake customers · 2024

stolen passwords

on accounts with no MFA



nearly all

AT&T wireless customers' call and text records



THE HUMAN DOOR

iCloud photos · 2014

phishing

targeted passwords and security questions



celebrity accounts

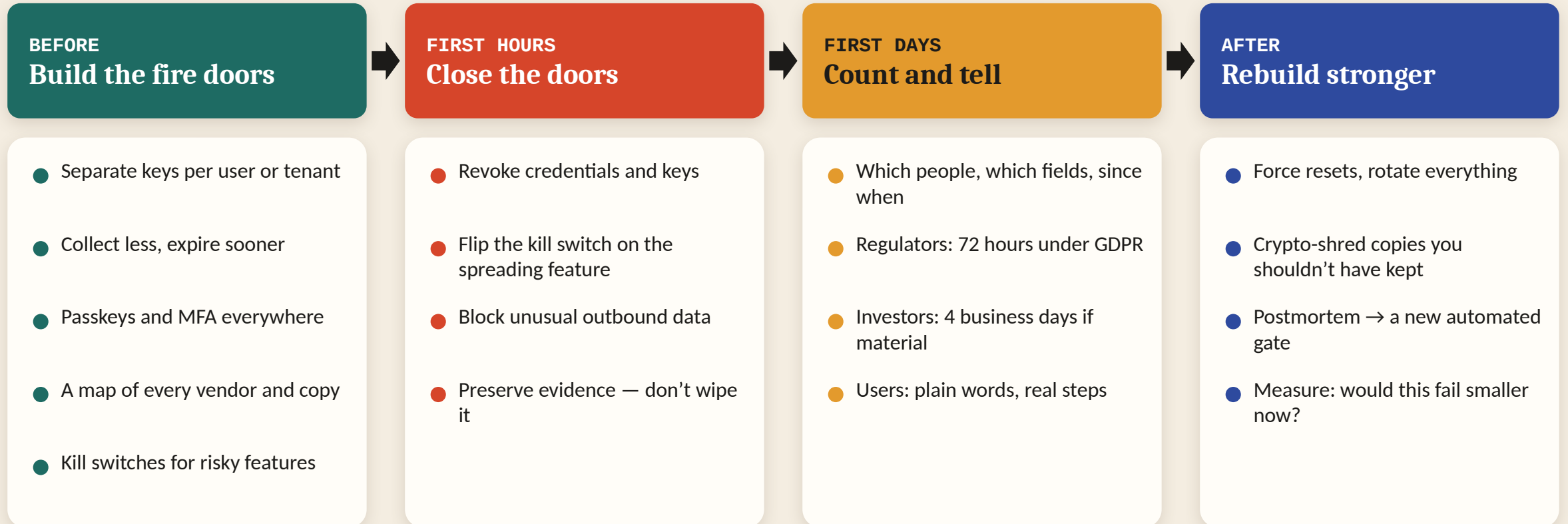
exposed — Apple then expanded two-factor and alerts

• THE BUTTON

Breach size = the doors you left open × the people each door can see.

When it hits the fan: contain it like a fire

Buildings survive fires because of fire doors, not smoke alarms. Build the doors before the smoke.



• THE BUTTON

You can't stop every fire. You can decide, in advance, how many rooms it reaches.

Apple vs Meta: a decade-long feud, in eight moves

Read the dates. The rhetoric escalates exactly when the money is at stake.

2014

APPLE

Tim Cook's privacy letter: when a service is free, you're not the customer — you're the product.

2018

APPLE

After Cambridge Analytica, Cook says Apple could make a fortune monetizing customers — and chooses not to.

2019

APPLE

Apple revokes Facebook's internal-app certificate over a research app that paid users, including teens, for deep phone access.

2020

META

Full-page newspaper ads: "standing up to Apple for small businesses everywhere."

2021

APPLE

ATT ships in iOS 14.5. Cook: a business built on misleading users deserves reform, not praise.

2022

META

Meta estimates a ~\$10B revenue hit from ATT; its stock loses about a quarter of its value in a day.

2023

META

Meta's complaint helps trigger Italy's ATT probe — which ends in a €98.6M fine (2025).

2024

APPLE

Apple says Meta's 15 interoperability requests under EU rules would expose users' data.

• THE BUTTON

It isn't a privacy debate. It's two business models fighting over one screen.

Apple owns the road. Meta owns the billboards.

Why the hyperbole? Each side's strongest argument is real — and so is its weakest spot.

APPLE'S CASE

**Users deserve a plain choice.
Offered one, most declined to be tracked.**

*Weak spot: Apple is referee and player.
Regulators found its own apps got an easier path.*

META'S CASE

Cheap targeted ads let small businesses compete. Apple changed the rules on everyone else's business.

Weak spot: its record — Cambridge Analytica and a \$5B FTC penalty (2019).

WHAT ACTUALLY HAPPENED

Tracking didn't vanish.

It moved server-side — conversions APIs, first-party logins, modeled targeting.

Meta recovered.

AI-driven ad targeting rebuilt performance with less third-party data.

Middlemen lost.

Data brokers and small ad networks with no first-party data were squeezed hardest.

• THE BUTTON

Privacy rules don't kill the demand for data. They move it toward whoever sits closest to the user.

AI breaks eight assumptions privacy was built on

Every control in this guide assumed data sits in rows, used for one purpose, deleted on request. AI dissolves all three.

1 PURPOSE

Collected to run a feature. Now useful to train a model.

2 DELETION

You can delete a row. You can't easily delete what a model learned from it.

3 CONSENT

Permission to post a photo was never permission to train on it.

4 INFERENCE

Models guess what you never shared — health, mood, orientation — from what you did.

5 CONTEXT

A truly helpful assistant needs your mail, messages, and calendar in one place.

6 BOUNDARIES

Permissions were built per app. An agent acts across all of them at once.

7 INPUT = COMMAND

A web page or email can carry instructions that make an agent leak your data.

8 RETENTION

Prompts are records: a 2025 court order made OpenAI keep even deleted chats for months.

• THE BUTTON

AI makes every record training data, every guess a disclosure, every document a command.

Four AI features that became privacy lessons

None was malicious. Each was a feature whose privacy decision hid inside a default.



2024

Microsoft Recall

WHAT HAPPENED

Screenshots of everything, every few seconds — and researchers could read the stored database.

THE FIX

Relaunched opt-in, encrypted, gated by Windows Hello.



2025

Meta AI app

WHAT HAPPENED

A public “Discover” feed where some people unknowingly published private conversations.

THE FIX

Meta added clearer warnings before sharing.



2023

Samsung & ChatGPT

WHAT HAPPENED

Engineers pasted internal source code into a public chatbot to debug it.

THE FIX

Samsung restricted generative AI tools at work.



2025

Deleted chats, kept

WHAT HAPPENED

A copyright lawsuit led a court to order OpenAI to preserve chats users had deleted.

THE FIX

The order was lifted for new chats in September 2025.

• THE BUTTON

A share button, a memory, a screenshot timer: each is a privacy decision disguised as a feature.

Where does the thinking happen? Three AI architectures

The industry is converging on the design Apple shipped in 2024: rivals now build the same kind of enclave.

	CLOUD BY DEFAULT Send it all to the server	VERIFIABLE PRIVATE CLOUD Sealed servers you can check	ON DEVICE Nothing leaves the phone
Capability	Largest models	Large models	Smaller models
Who can see it	The provider, by policy	No one, by design — attested	Only you
How you know	Trust the privacy policy	Published software images, remote attestation	It never left
Examples	Most chatbots and cloud assistants	Apple PCC (2024) · Google Private AI Compute (2025)	Keyboard, Photos, on-device summaries

• THE BUTTON

Trust used to be a paragraph in a privacy policy. Now it can be a cryptographic proof.

Design every system as if “Forget me” had to work

Imagine one button that erases a person everywhere. Could your system honor it today?



WHAT MAKES THE BUTTON POSSIBLE

A map of every copy · a key per person, so deleting the key deletes the data · deletion APIs in every vendor contract · lineage for training data · short retention by default.

THREE QUESTIONS FOR ANY PRODUCT

- 1 Who makes money from this data?
- 2 Who could force us to hand it over?
- 3 What does our worst day look like?

• THE BUTTON

If you can't build the Forget-me button, you don't control the data. The data controls you.

A worked design review, move by move

Prompt: “Design Frequent Places — the phone suggests where you are heading next.”

1 CLARIFY

Who is it for? What accuracy matters? What must never leak?

2 DRAW

Sensors → on-device model → suggestion UI.
Mark what could leave the device.

3 FIND EXPOSURE

Home, work, clinic, place of worship — a location history is a diary.

4 TWO DESIGNS

A: server-side history. B: on-device learning, end-to-end encrypted sync, no server-readable history.

5 TRADE-OFFS

B loses some cross-device quality; recover it with encrypted sync, not plaintext.

6 RECOMMEND

Ship B. Controls: off switch, history view, delete, short retention.

SHIP B

Narrate the reasoning. In a real review, the path matters as much as the destination.

Explain risk as a decision

Senior leaders need consequence, options, and trade-off — not a schema dump.

RISK

What can happen?

EXPOSURE

Whose data, and how much?

LIKELIHOOD

Under what conditions?

CUSTOMER

Why does it matter to them?

OPTIONS

What can change, at what cost?

RECOMMEND

What decision is needed, by when?

To: VP, Wallet Engineering

Subject: **Decision by Friday** — precise location in fraud features

DECISION NEEDED

Risk: fraud features keep precise location for 12 months, joinable to identity.

Exposure: nearly all active users; reveals home and work patterns.

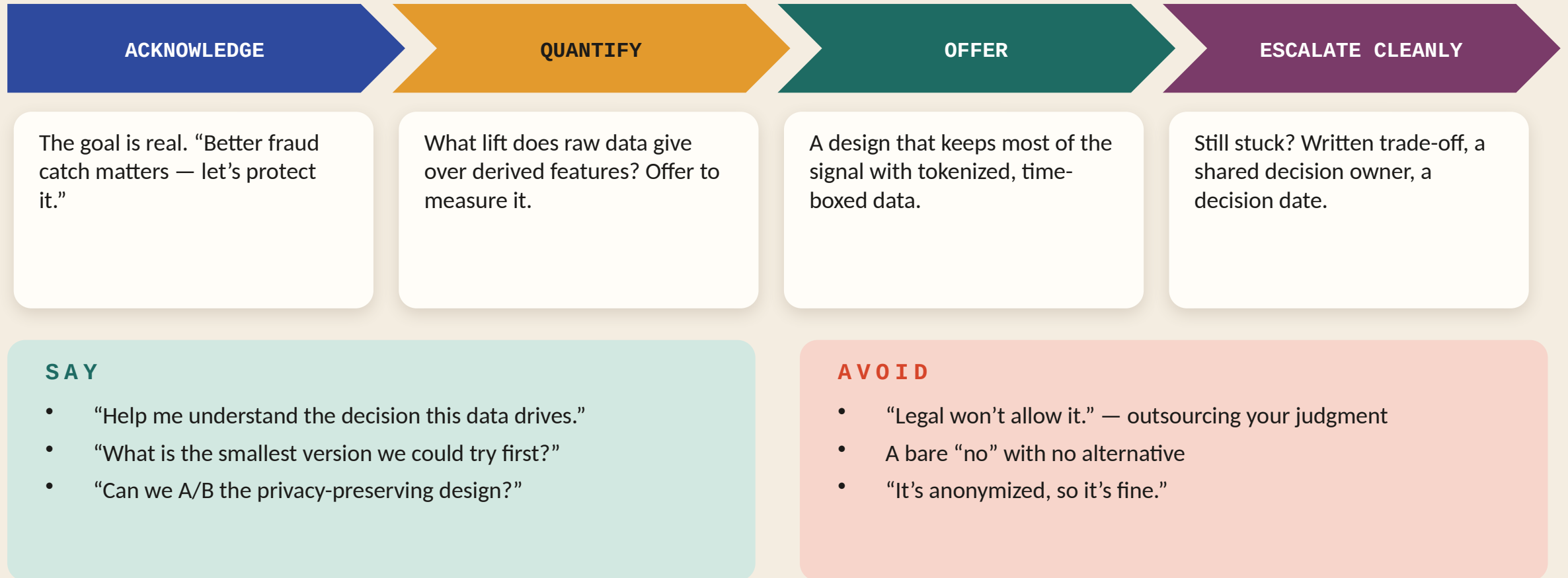
Likelihood: misuse or breach moderate; regulatory scrutiny high.

Options: (A) keep as is. (B) coarsen to city + 90-day TTL — ~0.4% recall loss, 2 eng-weeks. (C) on-device risk signal — best privacy, one quarter.

Recommendation: B now, C on the roadmap.

When product pushes back

“We need the raw data for the model.” How you answer decides whether they invite you back.



Can you answer at all three levels?

Real understanding survives follow-up questions. Answer out loud, then check the key on the next page.

BEGINNER

- B1** Privacy vs. security?
- B2** What counts as personal data?
- B3** Why minimize data?
- B4** What is a quasi-identifier?

INTERMEDIATE

- I1** Pseudonymization vs. anonymization?
- I2** How would you review consent?
- I3** When is on-device processing enough?
- I4** How do you make deletion provable?

EXPERT

- E1** What threat model does DP address?
- E2** How do privacy budgets compose?
- E3** Local vs. central DP — when each?
- E4** How would you keep fraud utility with less identity?

One-line model answers

Good enough to say out loud; strong enough to survive the first follow-up.

B1

Privacy asks whether data should be collected or used at all; security asks whether unauthorized parties can reach it.

B2

Anything that identifies, describes, locates, infers, or links to a person — device IDs and inferences included.

B3

Data you don't hold can't be breached, subpoenaed, misused, or repurposed.

B4

Fields harmless alone but identifying together — ZIP + birth date + sex.

I1

Pseudonymized data can be re-linked and is still personal data; anonymized has no reasonably likely route back.

I2

Was it informed and specific? Is the purpose recorded, checked at read time, and does revocation reach every copy?

I3

When the value is personal to one user. For cross-user learning, add local DP or secure aggregation.

I4

Lineage to find copies, tombstones, crypto-shredding for backups, and post-SLA verification scans.

E1

An attacker with any side information learning whether one person's data was used — membership and linkage.

E2

Losses add up: k queries at ϵ cost up to $k \cdot \epsilon$. Use tighter accountants and cap per-person contributions.

E3

Central: more accurate but trusts the curator. Local: no trust in the collector, but needs far more users.

E4

Tokenize, derive features, time-box history, isolate identity in an audited vault — and measure the recall cost.

Phrases that weaken privacy conversations — and better ones

Precise language is itself evidence of privacy judgment.

INSTEAD OF

SAY

~~“It’s encrypted, so it’s private.”~~



“Encryption stops outsiders. The question is whether we should hold it at all.”

~~“The data is anonymized.”~~



“It’s pseudonymized — still linkable. Here’s how we’d cut re-identification risk.”

~~“We’re GDPR compliant.”~~



“Here’s the lawful basis, the retention, and how deletion propagates.”

~~“Users consented.”~~



“Consent covers this purpose — here’s how we enforce it at read time.”

~~“We’ll add privacy later.”~~



“Building it in now costs a week; retrofitting costs a quarter.”

~~“Differential privacy solves it.”~~



“DP bounds this release — here’s the ϵ and how repeated queries are accounted for.”

Questions that reveal a team's privacy maturity

Use them when you join a team, review a vendor, or run a workshop.

01

When does privacy engineering enter product development?

Shaping designs — or cleaning up after them?

02

How often does a privacy finding change the architecture?

Shows how much real authority the function has.

03

Which controls are enforced by code, and which live in documents?

The enforcement ladder on p. 46, applied to a real team.

04

Where does the team most often disagree with product or engineering?

Surfaces the real tensions behind the process.

05

What privacy promise would you refuse to break, even for a launch date?

Reveals the values underneath the checklists.

A seven-day self-study path

Each day ends by explaining one idea out loud. Page numbers point back into this guide.

1

DAY 1

FOUNDATIONS

real-life scenarios • lifecycle • harms

pp. 03–20

2

DAY 2

LAW & RIGHTS

regulations • rights → requirements • consent

pp. 21–26

3

DAY 3

CONTROLS

identifiers • retention • de-identification • deletion

pp. 24–30

4

DAY 4

PETS

DP • budgets • k-anonymity • FL • MPC / HE / TEE

pp. 32–39

5

DAY 5

REVIEWS & TRACKING

threat models • reviews • cases • cookies • IDFA

pp. 40–64

6

DAY 6

APPLE & THE CORE

speak Apple • incentives • breaches • AI

pp. 66–104

7

DAY 7

PRACTICE HOUR

design exercise • risk memo • pushback • self-test

pp. 105–109

EVERY DAY

Explain one idea out loud. Record it. Listen once. Fix one thing.

The one-slide mental model

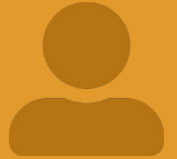
SEE THE DATA

What enters? · Where does it go? ·
How long does it stay?



SEE THE PERSON

What can be inferred? · Can contexts
be linked? · Can they control it?



REDUCE EXPOSURE

collect less · process locally · unlink ·
aggregate · expire



MAKE A DECISION

risk · options · utility ·
recommendation



Policy says what should happen. Architecture determines whether it actually happens.

Sixteen terms, one line each

If a term on an earlier page felt fuzzy, it is probably here.

Personal data	Any information relating to an identified or identifiable person.	DPIA	Data protection impact assessment for high-risk processing.
Quasi-identifier	A field that identifies someone only in combination (ZIP, birth date, sex).	Contextual integrity	Privacy as appropriate flows that match the norms of their context.
Pseudonymization	Replacing identifiers with surrogates; re-linkable with extra information.	Differential privacy	Outputs barely change whether or not any one person is included.
Anonymization	Processing so no one is reasonably likely to be re-identified.	ε (epsilon)	DP's privacy-loss parameter; smaller means stronger privacy.
Data minimization	Collect and keep only what the stated purpose needs.	k-anonymity	Each record shares its quasi-identifiers with at least k-1 others.
Purpose limitation	Use data only for the purposes it was collected for.	Secure aggregation	The server learns only the sum of many clients' updates.
Lawful basis	GDPR's six legal grounds for processing, such as consent or contract.	TEE	Trusted execution environment: hardware-isolated, attestable compute.
DSAR	Data subject access request: a person asks what you hold about them.	Crypto-shredding	Deleting data everywhere by destroying the key that encrypts it.

Go deeper after the deck

Primary sources beat summaries. Start with the Apple documents, then the classics.

● Apple Privacy apple.com/privacy	● Apple Platform Security guide support.apple.com/guide/security
● Apple Pay Security & Privacy support.apple.com/en-us/101554	● WebKit Tracking Prevention webkit.org/tracking-prevention
● Learning with Privacy at Scale machinelearning.apple.com/research/learning-with-privacy-at-scale	● Private Cloud Compute Security Guide security.apple.com/documentation/private-cloud-compute
● NIST Privacy Framework nist.gov/privacy-framework	● LINDDUN privacy threat modeling linddun.org
● Dwork & Roth, The Algorithmic Foundations of Differential Privacy (2014) free from the authors	● Sweeney, Simple Demographics Often Identify People Uniquely (2000) Carnegie Mellon University
● Nissenbaum, Privacy in Context (2010) Stanford University Press	● Cavoukian, Privacy by Design: The 7 Foundational Principles Information & Privacy Commissioner of Ontario

● Apple ● frameworks ● classic papers & books

THANK YOU FOR READING

**Privacy is the goal.
Security keeps it.
Law sets the minimum.
A feature puts it in people's hands.**

Share it and teach with it — please link back to the original.

PADDYSPEAKS.COM

Paddy Iyer · Status as of September 2026 — privacy moves fast, so check the primary sources on p. 115.



NEWBIE → EXPERT